

# REDVITAL

Plataforma Nacional para la Gestión Integral del Ciclo de Vida  
de la Donación de Sangre

## DOCUMENTO DE INFRAESTRUCTURA

Arkhé Software S.A.S.

*De la raíz a la red*

**Curso:** Arquitectura de Software Empresarial  
**Cliente:** Profesor de la asignatura, en el rol simulado de  
Ministerio de Salud y Protección Social  
**Entrega:** Review Sprint 2 y Planning Sprint 3 — Semana 8  
**Versión:** 1.0  
**Estado:** Aprobado para entrega  
**Fecha:** 22 de septiembre de 2026  
**Clasificación:** Uso interno del proyecto

## Control de versiones

| Versión | Fecha      | Autor        | Descripción del cambio                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                            |
|---------|------------|--------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| 1.0     | 22/09/2026 | Equipo Arkhé | Versión inicial. Realiza en configuración la topología de ADR-014 y las decisiones de ADR-007, ADR-008, ADR-015 y ADR-016: cinco zonas de confianza con cinco fronteras, pertenencia de cada contenedor a cada red, puertos, dieciocho aristas permitidas y el mecanismo que impone cada una, autorización de las operaciones internas, composición de Desarrollo y QA, orden de arranque, presupuesto de recursos, imágenes y endurecimiento, inventario y ciclo de vida de los secretos, roles de base de datos, modelo de amenazas de treinta celdas, observabilidad, respaldo y restauración, despliegue y reversión, configuración por ambiente, topología de referencia de Producción, riesgos aceptados y procedimientos de verificación con su evidencia. |

## Control de cambios

Primera versión controlada del documento. Sustituye la sección de infraestructura que el SAD V1.0 dedicaba a la configuración concreta de los ambientes, que desde el SAD V2.0 remite a este documento. Ante discrepancia entre este documento y un ADR, gana el ADR; ante discrepancia entre este documento y el SAD en una decisión de arquitectura, gana el SAD, y este documento se corrige. En toda cifra de configuración —puerto, red, límite, plazo— este documento es la fuente.

## Aprobaciones

| Rol                            | Responsable            | Firma / Fecha |
|--------------------------------|------------------------|---------------|
| DevOps                         | Veli                   |               |
| Arquitecta de Software         | Sara                   |               |
| QA / Tester                    | Tomás                  |               |
| Scrum Master / Project Manager | Carlos Santiago Pinzón |               |
| Product Owner                  | Alexander Aponte       |               |

La aprobación de DevOps es constitutiva: es el responsable de la configuración que este documento describe y de su custodia en los ambientes. La de la Arquitecta de Software acredita que la configuración realiza los ADR sin

---

apartarse de ellos. La de QA acredita que cada control tiene un procedimiento de verificación ejecutable y una evidencia que lo cierra.

# Índice

|                                                               |           |
|---------------------------------------------------------------|-----------|
| <b>Control de versiones</b>                                   | <b>1</b>  |
| <b>Control de cambios</b>                                     | <b>1</b>  |
| <b>Aprobaciones</b>                                           | <b>1</b>  |
| <b>1. Introducción</b>                                        | <b>6</b>  |
| 1.1. Propósito . . . . .                                      | 6         |
| 1.2. Alcance . . . . .                                        | 6         |
| 1.3. Relación con los demás artefactos . . . . .              | 7         |
| 1.4. Definiciones . . . . .                                   | 7         |
| 1.5. Referencias . . . . .                                    | 8         |
| <b>2. Principios, restricciones y supuestos</b>               | <b>9</b>  |
| 2.1. Restricciones que gobiernan la infraestructura . . . . . | 9         |
| 2.2. Principios . . . . .                                     | 10        |
| 2.3. Supuestos de dimensionamiento . . . . .                  | 10        |
| <b>3. Topología y red</b>                                     | <b>11</b> |
| 3.1. Zonas de confianza y fronteras . . . . .                 | 11        |
| 3.2. Redes de contenedores . . . . .                          | 13        |
| 3.3. Puertos . . . . .                                        | 14        |
| 3.4. Aristas permitidas . . . . .                             | 14        |
| 3.5. Autorización de las operaciones internas . . . . .       | 16        |
| 3.6. Invariantes de la topología . . . . .                    | 16        |
| <b>4. Cómputo y contenedores</b>                              | <b>17</b> |
| 4.1. Composición por ambiente . . . . .                       | 17        |
| 4.2. Orden de arranque . . . . .                              | 18        |
| 4.3. Sondas de salud . . . . .                                | 18        |
| 4.4. Presupuesto de recursos . . . . .                        | 19        |
| 4.5. Requisitos de los anfitriones . . . . .                  | 20        |
| 4.6. Reglas comunes de ejecución . . . . .                    | 21        |
| <b>5. Imágenes y endurecimiento</b>                           | <b>21</b> |
| 5.1. Imágenes por componente . . . . .                        | 21        |
| 5.2. Endurecimiento de contenedores . . . . .                 | 22        |
| <b>6. Almacenamiento y datos</b>                              | <b>23</b> |
| 6.1. Bases y volúmenes . . . . .                              | 23        |
| 6.2. Roles de base de datos . . . . .                         | 23        |
| 6.3. Aislamiento y comprobación . . . . .                     | 24        |
| <b>7. Seguridad y accesos</b>                                 | <b>24</b> |
| 7.1. Defensa en capas . . . . .                               | 24        |
| 7.2. Borde . . . . .                                          | 25        |
| 7.3. Autenticación entre componentes . . . . .                | 26        |
| 7.4. Inventario de secretos . . . . .                         | 26        |
| 7.5. Rotación de la clave de firma . . . . .                  | 28        |
| 7.6. Acceso administrativo a la máquina de QA . . . . .       | 28        |

|                                                                    |           |
|--------------------------------------------------------------------|-----------|
| <b>8. Modelo de amenazas</b>                                       | <b>28</b> |
| <b>9. Integración continua como control</b>                        | <b>31</b> |
| 9.1. Etapas por repositorio . . . . .                              | 31        |
| 9.2. Detección de secretos . . . . .                               | 31        |
| 9.3. Escaneo de imágenes . . . . .                                 | 31        |
| 9.4. Cadena de suministro de la integración continua . . . . .     | 31        |
| <b>10. Observabilidad</b>                                          | <b>32</b> |
| 10.1. Métricas . . . . .                                           | 32        |
| 10.2. Tableros y alertas . . . . .                                 | 32        |
| 10.3. Registros . . . . .                                          | 33        |
| <b>11. Respaldo, despliegue y recuperación</b>                     | <b>33</b> |
| 11.1. Respaldo . . . . .                                           | 33        |
| 11.2. Restauración . . . . .                                       | 34        |
| 11.3. Despliegue en QA . . . . .                                   | 34        |
| 11.4. Reversión . . . . .                                          | 34        |
| <b>12. Ambientes y configuración</b>                               | <b>35</b> |
| 12.1. Comparación de ambientes . . . . .                           | 35        |
| 12.2. Variables de configuración . . . . .                         | 35        |
| 12.3. Pila de medición . . . . .                                   | 36        |
| 12.4. Topología de referencia de Producción . . . . .              | 36        |
| <b>13. Riesgos de infraestructura aceptados</b>                    | <b>37</b> |
| <b>14. Verificación</b>                                            | <b>38</b> |
| 14.1. Correspondencia con el backlog . . . . .                     | 40        |
| <b>15. Gobierno del documento</b>                                  | <b>40</b> |
| <b>A. Declaración de un servicio en el archivo de orquestación</b> | <b>41</b> |
| <b>B. Configuración del proxy de borde</b>                         | <b>42</b> |

## Índice de figuras

|    |                                                      |    |
|----|------------------------------------------------------|----|
| 1. | Topología de QA por zonas, redes y puertos . . . . . | 12 |
|----|------------------------------------------------------|----|

## Índice de tablas

|     |                                                                              |    |
|-----|------------------------------------------------------------------------------|----|
| 3.  | Relación de este documento con los demás artefactos del proyecto. . . . .    | 7  |
| 4.  | Términos de infraestructura empleados en este documento. . . . .             | 8  |
| 5.  | Documentos y fuentes que este documento aplica o de los que depende. . . . . | 8  |
| 6.  | Restricciones con consecuencia directa sobre la infraestructura. . . . .     | 9  |
| 7.  | Supuestos sobre los que se dimensiona la infraestructura. . . . .            | 10 |
| 8.  | Zonas de confianza y sus componentes. . . . .                                | 11 |
| 9.  | Fronteras de confianza y controles que las vigilan. . . . .                  | 11 |
| 10. | Pertenencia de cada contenedor a cada red. . . . .                           | 13 |
| 11. | Puertos por contenedor. . . . .                                              | 14 |
| 12. | Aristas permitidas y mecanismo que las impone. . . . .                       | 14 |
| 13. | Operaciones internas y sujetos admitidos. . . . .                            | 16 |
| 14. | Invariantes de la topología y verificación que los comprueba. . . . .        | 16 |
| 15. | Contenedores por ambiente. . . . .                                           | 17 |
| 16. | Orden de arranque y condición de cada dependencia. . . . .                   | 18 |
| 17. | Sondas de salud por contenedor. . . . .                                      | 19 |
| 18. | Presupuesto de memoria y CPU por contenedor. . . . .                         | 19 |
| 19. | Requisitos mínimos de los anfitriones. . . . .                               | 20 |
| 20. | Imágenes de construcción y de ejecución por componente. . . . .              | 21 |
| 21. | Controles de endurecimiento de contenedores. . . . .                         | 22 |
| 22. | Bases de datos, propietario y volumen. . . . .                               | 23 |
| 23. | Roles de cada base y privilegios. . . . .                                    | 24 |
| 24. | Capas de control de una petición externa. . . . .                            | 25 |
| 25. | Configuración del proxy de borde. . . . .                                    | 25 |
| 26. | Inventario de secretos, custodio, origen y rotación. . . . .                 | 27 |
| 27. | Modelo de amenazas por frontera y categoría STRIDE. . . . .                  | 29 |
| 28. | Etapas de la integración continua por tipo de repositorio. . . . .           | 31 |
| 29. | Métricas mínimas y escenario que sostienen. . . . .                          | 32 |
| 30. | Alertas de QA. . . . .                                                       | 33 |
| 31. | Política de respaldo de QA. . . . .                                          | 33 |
| 32. | Configuración por ambiente. . . . .                                          | 35 |
| 33. | Variables de configuración principales. . . . .                              | 36 |
| 34. | Diferencias de la topología de referencia de Producción. . . . .             | 37 |
| 35. | Riesgos de infraestructura aceptados. . . . .                                | 37 |
| 36. | Procedimientos de verificación y evidencia que los cierra. . . . .           | 38 |
| 37. | Tareas del Sprint 2 y su lugar en este documento. . . . .                    | 40 |
| 38. | Responsabilidad sobre los contenidos de este documento. . . . .              | 41 |

# 1. Introducción

## 1.1 Propósito

Este documento describe cómo se despliega, se comunica, se protege, se observa y se recupera RedVital. El SAD decide dónde están las fronteras y por qué; este documento las convierte en configuración: redes, puertos, imágenes, secretos, límites de recursos, procedimientos y comprobaciones.

Su criterio de inclusión es el complementario del SAD: entra aquí todo lo que un integrante necesita para levantar, operar, verificar o reconstruir un ambiente, y que se puede comprobar sobre la composición real. Una afirmación de este documento que no se pueda contrastar con el archivo de orquestación, con una imagen o con un procedimiento ejecutado está mal escrita.

## 1.2 Alcance

### Este documento cubre

- Las zonas de confianza, las fronteras entre ellas y la pertenencia de cada contenedor a cada red (Sección 3).
- Los puertos, las aristas permitidas y el mecanismo que impone cada una, incluida la autorización de las operaciones internas (Sección 3).
- La composición de contenedores por ambiente, el orden de arranque, los sondeos de salud y el presupuesto de recursos (Sección 4).
- Las imágenes de contenedor y su endurecimiento (Sección 5).
- Las bases de datos, sus roles y su aislamiento (Sección 6).
- El borde, la autenticación entre componentes, los secretos y su rotación (Sección 7).
- El modelo de amenazas por frontera (Sección 8).
- La integración continua como control de seguridad (Sección 9).
- La observabilidad (Sección 10).
- El respaldo, la restauración, el despliegue y la reversión (Sección 11).
- La configuración por ambiente y la topología de referencia de Producción (Sección 12).
- Los riesgos de infraestructura aceptados (Sección 13).
- Los procedimientos de verificación y la evidencia que cierra cada uno (Sección 14).

### Este documento no cubre

- Las decisiones de arquitectura, sus alternativas y su justificación, que viven en los ADR y se sintetizan en el SAD V2.0.
- Las vistas 4+1 y el modelo C4, que corresponden al SDD V1. Su vista física referencia este documento y no lo copia.
- El modelo de datos, los contratos de las operaciones y el catálogo de errores, que corresponden al DD V2.
- El estado de ejecución de cada verificación. Este documento fija el procedimiento y la evidencia; el resultado de cada ejecución se registra en el Informe de Evaluación del sprint en que se ejecuta.

### 1.3 Relación con los demás artefactos

**Tabla 3:** Relación de este documento con los demás artefactos del proyecto.

| Artefacto                                   | Qué aporta a este documento, y qué toma de él                                                                                                                                                                           |
|---------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| ADR-007                                     | API Gateway: rutas, rutas públicas, compuerta, límite de tasa en dos escalas, plazos, correlación y entrega de denegaciones.                                                                                            |
| ADR-008                                     | Token de sesión: emisor, algoritmo, vigencias, custodia de la clave privada por ambiente, tokens de servicio, publicación de claves y rotación.                                                                         |
| ADR-009                                     | Línea de plataforma Java 25 con distribución Eclipse Temurin.                                                                                                                                                           |
| ADR-014                                     | Servicios, propiedad de los datos, contenedores, zonas, redes, aristas permitidas, bandeja de salida, orden de arranque y repositorios.                                                                                 |
| ADR-015                                     | Proxy de borde: certificados, cabeceras, tamaño de cuerpo, registro de acceso.                                                                                                                                          |
| ADR-016                                     | Bitácora de auditoría en cuatro series y entrega asíncrona de las denegaciones del gateway.                                                                                                                             |
| SAD V2.0                                    | Aporta los escenarios de calidad que esta configuración debe hacer verificables y las zonas de confianza. Toma de este documento la matriz de alcanzabilidad y la configuración de los ambientes.                       |
| Herramientas, Políticas y Lineamientos V3.0 | Aporta el catálogo de tecnología permitida y las políticas de contenerización, integración continua y seguridad operativa. Este documento no introduce ninguna tecnología que no figure allí en anillo <b>Adoptar</b> . |
| SDD V1                                      | Toma de este documento la vista física y la referencia; documenta la prueba de concepto del gateway.                                                                                                                    |
| DD V2                                       | Aporta las entidades de cada base y los contratos; toma de este documento los roles de base de datos y las operaciones de solo anexo.                                                                                   |
| Backlog V3                                  | Las tareas T-301 a T-312 y T-401 a T-411 producen o verifican lo que este documento describe.                                                                                                                           |

### 1.4 Definiciones

Los términos del dominio están definidos en el SRS V3.0 y los arquitectónicos en el SAD V2.0. Aquí se definen los propios de la infraestructura.

**Tabla 4:** Términos de infraestructura empleados en este documento.

| <b>Término</b>           | <b>Definición</b>                                                                                                                                                                                      |
|--------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Arista permitida         | Comunicación entre dos componentes que figura en la Tabla 12. Toda comunicación que no figura allí está prohibida.                                                                                     |
| Contenedor de larga vida | Contenedor que permanece en ejecución mientras el ambiente opera. Se distingue del trabajo efímero.                                                                                                    |
| Frontera                 | Límite entre dos zonas de confianza contiguas, o entre el exterior y la zona de borde, en el que se aplica un conjunto propio de controles.                                                            |
| Pila de medición         | Instancia de la composición de QA, con otro nombre de proyecto, sobre la que se ejecutan las pruebas de carga y de sobrecarga.                                                                         |
| Puerto de gestión        | Puerto 8081 de cada servicio y del gateway, que expone únicamente la salud y las métricas. El gateway no lo enruta y ningún componente de otra zona lo alcanza salvo Prometheus.                       |
| Puerto de negocio        | Puerto 8080 de cada servicio con rutas, por el que se atienden las operaciones publicadas y las internas.                                                                                              |
| Rol de propietario       | Rol de base de datos dueño del esquema, con permiso de definición de datos. Solo lo usa el trabajo de migración de esa base.                                                                           |
| Rol de servicio          | Rol de base de datos con el que se conecta el servicio propietario. Manipula datos, no define esquema, y no puede modificar ni borrar las tablas de solo anexo.                                        |
| Sonda de salud           | Programa que el motor de contenedores ejecuta dentro de cada contenedor para decidir si está sano. En las imágenes sin intérprete de órdenes se invoca en forma de lista de ejecución, sin intérprete. |
| Trabajo efímero          | Contenedor que ejecuta una tarea y termina: los trabajos de migración, de respaldo y de restauración.                                                                                                  |
| Zona de confianza        | Agrupación de componentes con el mismo nivel de exposición, aislada de las demás por una red de contenedores propia.                                                                                   |

## 1.5 Referencias

**Tabla 5:** Documentos y fuentes que este documento aplica o de los que depende.

| <b>Ref.</b> | <b>Fuente</b>                                                                                          |
|-------------|--------------------------------------------------------------------------------------------------------|
| [1]         | Documento de Arquitectura de Software SAD V2.0.                                                        |
| [2]         | Documento de Herramientas, Políticas y Lineamientos V3.0.                                              |
| [3]         | Especificación de Requerimientos SRS V3.0.                                                             |
| [4]         | ADR-007 a ADR-009 y ADR-013 a ADR-016, aprobados en Mesa de Arquitectura del 22 de septiembre de 2026. |
| [5]         | Backlog V3, Sprint 2.                                                                                  |

*Continúa en la página siguiente*

| Ref. | Fuente                                                                                                                                         |
|------|------------------------------------------------------------------------------------------------------------------------------------------------|
| [6]  | Docker. <i>Compose file reference</i> : redes, secretos, sondas de salud y dependencias por condición.                                         |
| [7]  | Microsoft. <i>.NET container images</i> : imágenes <i>chiseled</i> de ASP.NET Core 10.                                                         |
| [8]  | Google Container Tools. <i>Distroless container images</i> , familia Debian 13.                                                                |
| [9]  | PostgreSQL Global Development Group. <i>PostgreSQL 16 documentation</i> : roles, privilegios, <code>pg_dump</code> y <code>pg_restore</code> . |
| [10] | Caddy. <i>Caddyfile documentation</i> : autoridad interna, <code>header</code> , <code>request_body</code> , <code>log</code> .                |
| [11] | Shostack, A. <i>Threat Modeling: Designing for Security</i> . Método STRIDE.                                                                   |
| [12] | OWASP. <i>Docker Security Cheat Sheet</i> y <i>Application Security Verification Standard</i> .                                                |
| [13] | Wiggins, A. <i>The Twelve-Factor App</i> .                                                                                                     |

## 2. Principios, restricciones y supuestos

### 2.1 Restricciones que gobiernan la infraestructura

**Tabla 6:** Restricciones con consecuencia directa sobre la infraestructura.

| ID     | Restricción                                            | Consecuencia en este documento                                                                                                                                         |
|--------|--------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| RD-01  | Solución distribuida, sin monolito modular.            | Cinco servicios con despliegue propio, cuatro bases con propietario exclusivo y una red de datos por base.                                                             |
| RD-03  | Todo contenerizado.                                    | Todo componente ejecutable y toda tarea —migración, respaldo, restauración— corre como contenedor. Orquestación con Compose, sin clúster.                              |
| RD-06  | Múltiples repositorios.                                | La configuración de este documento vive en <code>redvital-infra</code> ; cada imagen se construye en el repositorio de su componente.                                  |
| RD-08  | Seguridad de primer orden.                             | Cinco fronteras con controles propios, mínimo privilegio en contenedores y bases, secretos fuera de las imágenes y verificación automática en la integración continua. |
| RN-01  | Ley 1581 de 2012.                                      | Ningún registro, métrica, etiqueta ni respaldo compartido contiene causa clínica, datos personales innecesarios ni contenido de token.                                 |
| RNF-11 | Instalabilidad en otro entorno sin modificar imágenes. | Toda diferencia entre ambientes se expresa como variable o secreto; ninguna imagen contiene valores de un ambiente.                                                    |

*Continúa en la página siguiente*

| ID    | Restricción                           | Consecuencia en este documento                                                                                              |
|-------|---------------------------------------|-----------------------------------------------------------------------------------------------------------------------------|
| CP-02 | Equipo junior, nueve horas semanales. | Una sola herramienta de orquestación en los dos ambientes construidos, sin plano de control ni intermediario de mensajería. |
| CP-03 | Presupuesto cero.                     | Máquina virtual institucional, imágenes oficiales y herramientas de licencia abierta.                                       |
| CP-04 | Datos sintéticos.                     | Los respaldos de QA no se cifran; la topología de Producción sí lo exige.                                                   |

## 2.2 Principios

1. **Denegar por defecto.** Una comunicación, un puerto, una capacidad del núcleo o un privilegio de base de datos que no está declarado en este documento no existe en la composición.
2. **Aislar por red lo que se puede aislar por red, y autenticar lo demás.** Las fronteras entre zonas se imponen con redes separadas. Las aristas dentro de la Zona 3, que comparte una red, se imponen con tokens y con autorización por operación. Ningún control descansa en que un componente se porte bien.
3. **Un único punto de exposición.** Solo el proxy de borde publica puertos al anfitrión.
4. **Mínimo privilegio en tres capas.** Contenedor sin privilegios, rol de base de datos sin definición de esquema y token con el alcance del llamador.
5. **La misma imagen en todos los ambientes.** Lo que cambia entre ambientes es configuración inyectada, nunca contenido de la imagen.
6. **Todo control tiene su verificación.** Cada control de este documento remite a un procedimiento de la Sección 14 y a la evidencia que lo cierra.

## 2.3 Supuestos de dimensionamiento

**Tabla 7:** Supuestos sobre los que se dimensiona la infraestructura.

| Supuesto         | Valor y origen                                                                                                                                          |
|------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------|
| Volumen de datos | Conjunto sintético de referencia: 5.000 donantes, 12.000 donaciones, 30.000 unidades y cerca de 95.000 eventos de trazabilidad (SAD V2.0, Sección 4.2). |
| Carga nominal    | 20 usuarios concurrentes en consulta de inventario; 50 en el pico de una campaña; 200 en la sobrecarga deliberada (EC-07, EC-15, EC-16, EC-37).         |
| Puesta en marcha | Un comando, diez minutos o menos, en Windows, macOS y Linux (EC-23).                                                                                    |
| Coexistencia     | Menos de 4 GB de memoria agregada en reposo en Desarrollo (EC-27).                                                                                      |
| Disponibilidad   | 99 % sobre el sondeo de salud en la ventana de evaluación; un contenedor caído vuelve a sano en 60 segundos o menos (EC-07).                            |

*Continúa en la página siguiente*

| Supuesto        | Valor y origen                                                                                                  |
|-----------------|-----------------------------------------------------------------------------------------------------------------|
| Recuperación    | Tiempo de recuperación de 4 horas o menos y pérdida máxima de 24 horas por base (EC-09).                        |
| Anfitrión de QA | Una máquina virtual institucional Linux con Docker Engine y Compose, con los requisitos mínimos de la Tabla 19. |

### 3. Topología y red

#### 3.1 Zonas de confianza y fronteras

La topología agrupa los componentes en cinco zonas de confianza (ADR-014). Entre el exterior y la zona de borde, y entre cada par de zonas contiguas, hay una frontera con controles propios. Las fronteras se numeran igual en este documento, en el SAD V2.0 y en ADR-015.

**Tabla 8:** Zonas de confianza y sus componentes.

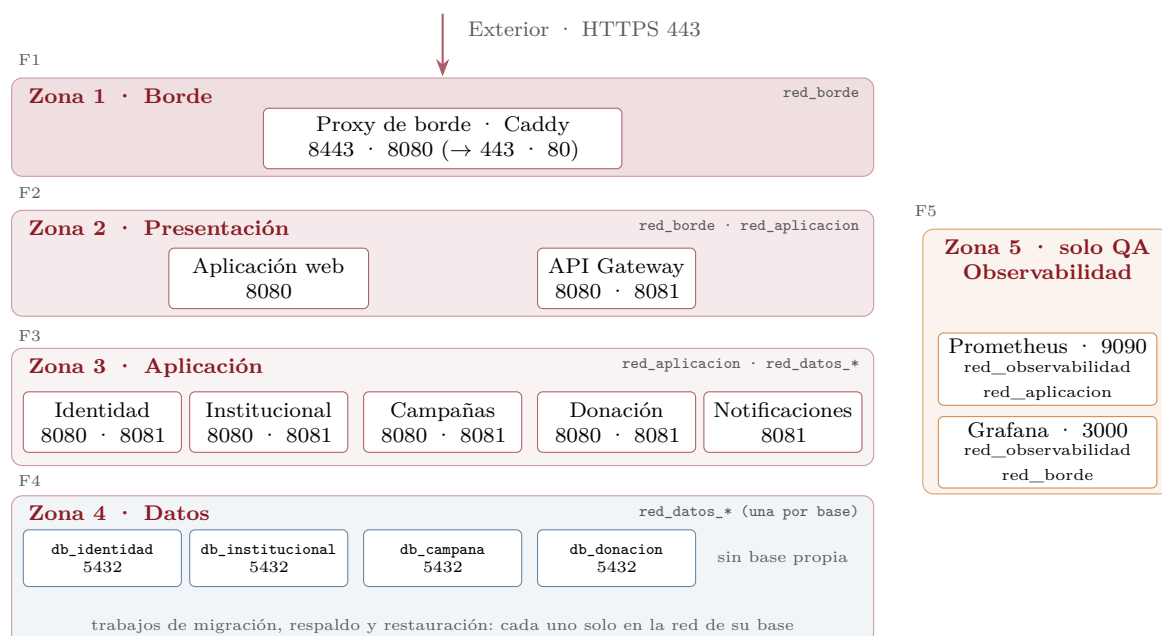
| Zona                         | Componentes                                                            | Exposición                                                                             |
|------------------------------|------------------------------------------------------------------------|----------------------------------------------------------------------------------------|
| 1 · Borde                    | Proxy de borde (Caddy)                                                 | Única zona alcanzable desde fuera del anfitrión.                                       |
| 2 · Presentación             | Aplicación web, API Gateway                                            | Alcanzable solo desde el borde.                                                        |
| 3 · Aplicación               | Identidad, Institucional, Campañas, Donación, Notificaciones           | Alcanzable solo desde el gateway y, entre sus componentes, por las aristas permitidas. |
| 4 · Datos                    | Cuatro PostgreSQL y los trabajos de migración, respaldo y restauración | Cada base, alcanzable solo desde su servicio propietario y sus trabajos.               |
| 5 · Observabilidad (solo QA) | Prometheus, Grafana                                                    | Prometheus, alcanzable solo desde Grafana; Grafana, solo a través del borde.           |

**Tabla 9:** Fronteras de confianza y controles que las vigilan.

| ID | Frontera          | Quién la vigila          | Controles                                                                                                                                                                    |
|----|-------------------|--------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| F1 | Exterior ↔ Zona 1 | Proxy de borde (ADR-015) | TLS 1.2 y 1.3, redirección a HTTPS, cabeceras de seguridad, cuerpo máximo de 1 MiB, sustitución de las cabeceras <b>X-Forwarded-*</b> y registro de acceso sin credenciales. |

*Continúa en la página siguiente*

| ID | Frontera                                       | Quién la vigila                  | Controles                                                                                                                                                                            |
|----|------------------------------------------------|----------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| F2 | Zona 1 ↔ Zona 2                                | API Gateway (ADR-007)            | Validación del token, compuerta por ruta y rol, límite de tasa en dos escalas, identificador de correlación, rutas internas nunca enrutadas y entrega de denegaciones a la bitácora. |
| F3 | Zona 2 ↔ Zona 3, y aristas dentro de la Zona 3 | Cada servicio (ADR-008, ADR-011) | Revalidación del token, filtrado por jurisdicción a nivel de registro, autorización de cada operación interna por el sujeto del token y plazo de espera en toda llamada.             |
| F4 | Zona 3 ↔ Zona 4                                | Cada base de datos               | Red de datos propia por base, rol de servicio sin definición de esquema y sin modificación de tablas de solo anexo, ningún superusuario en uso.                                      |
| F5 | Zona 3 ↔ Zona 5                                | Prometheus y Grafana             | Raspado solo del puerto de gestión, etiquetas sin datos protegidos, Prometheus sin ruta externa, Grafana con usuarios nominales y tableros aprovisionados de solo lectura.           |



**Figura 1:** Topología de QA por zonas, redes y puertos. Solo el proxy de borde publica puertos al anfitrión: 443 y 80, que llegan a los puertos internos 8443 y 8080 del contenedor. Cada servicio atiende sus operaciones en el puerto de negocio 8080 y expone salud y métricas en el puerto de gestión 8081; el trabajador de Notificaciones solo tiene puerto de gestión. En Desarrollo no existe la Zona 5.

### 3.2 Redes de contenedores

Cada zona tiene su red, y cada base tiene la suya dentro de la Zona 4. Todas las redes, salvo `red_borde`, se declaran internas: no tienen salida al exterior ni puertos publicados.

**Tabla 10:** Pertenencia de cada contenedor a cada red.

| Contenedor                      | <i>red_borde</i> | <i>red_aplicacion</i> | <i>red_datos_identidad</i> | <i>red_datos_institucional</i> | <i>red_datos_campana</i> | <i>red_datos_donacion</i> | <i>red_observabilidad</i> |
|---------------------------------|------------------|-----------------------|----------------------------|--------------------------------|--------------------------|---------------------------|---------------------------|
| Proxy de borde                  | ●                |                       |                            |                                |                          |                           |                           |
| Aplicación web                  | ●                |                       |                            |                                |                          |                           |                           |
| API Gateway                     | ●                | ●                     |                            |                                |                          |                           |                           |
| Identidad                       |                  | ●                     | ●                          |                                |                          |                           |                           |
| Institucional                   |                  | ●                     |                            | ●                              |                          |                           |                           |
| Campanas                        |                  | ●                     |                            |                                | ●                        |                           |                           |
| Donación                        |                  | ●                     |                            |                                |                          | ●                         |                           |
| Notificaciones                  |                  | ●                     |                            |                                |                          |                           |                           |
| db_identidad y sus trabajos     |                  |                       | ●                          |                                |                          |                           |                           |
| db_institucional y sus trabajos |                  |                       |                            | ●                              |                          |                           |                           |
| db_campana y sus trabajos       |                  |                       |                            |                                | ●                        |                           |                           |
| db_donacion y sus trabajos      |                  |                       |                            |                                |                          | ●                         |                           |
| Prometheus (QA)                 |                  | ●                     |                            |                                |                          |                           | ●                         |
| Grafana (QA)                    | ●                |                       |                            |                                |                          |                           | ●                         |

**Consecuencias de la tabla.** Ningún contenedor de las Zonas 1 y 2 comparte red con una base, de modo que el borde, la aplicación web y el gateway no pueden abrir una conexión hacia ninguna base, aunque se comprometan. Ningún servicio comparte red con la base de otro. Esas dos propiedades son estructurales: no dependen de ninguna credencial.

Dos redes son compartidas por más de dos componentes, y dentro de ellas la red no distingue aristas:

- En `red_borde` conviven el borde, la aplicación web, el gateway y, en QA, Grafana. Ninguno de los tres pares del borde obtiene de otro más de lo que obtiene un cliente externo a través del borde: la aplicación web sirve contenido estático sin sesión, el gateway exige token en toda ruta protegida y Grafana exige inicio de sesión.
- En `red_aplicacion` conviven el gateway, los cinco servicios y, en QA, Prometheus. Allí las aristas 5 a 14 y 17 de la Tabla 12 se imponen por autenticación y autorización: todo puerto

de negocio exige un token válido salvo las rutas públicas y la publicación de claves, y cada operación interna acepta únicamente los sujetos de la Tabla 13.

### 3.3 Puertos

**Tabla 11:** Puertos por contenedor.

| Contenedor                                   | Puerto interno        | Publicado | Uso                                                                                                                                                                                                       |
|----------------------------------------------|-----------------------|-----------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Proxy de borde                               | 8443/tcp,<br>8080/tcp | 443, 80   | HTTPS; HTTP solo para redirigir a HTTPS. El proceso escucha en puertos no privilegiados, de modo que no necesita ninguna capacidad del núcleo. La interfaz de administración de Caddy está deshabilitada. |
| Aplicación web                               | 8080/tcp              | —         | Recursos estáticos.                                                                                                                                                                                       |
| API Gateway                                  | 8080/tcp,<br>8081/tcp | —         | Rutas /v1/* recibidas del borde; gestión: salud y métricas.                                                                                                                                               |
| Identidad, Institucional, Campañas, Donación | 8080/tcp,<br>8081/tcp | —         | Operaciones publicadas e internas; gestión: salud y métricas.                                                                                                                                             |
| Notificaciones                               | 8081/tcp              | —         | Solo gestión. No atiende operaciones.                                                                                                                                                                     |
| PostgreSQL (cuatro)                          | 5432/tcp              | —         | Conexiones de su servicio y de sus trabajos.                                                                                                                                                              |
| Prometheus                                   | 9090/tcp              | —         | Consulta de series desde Grafana. Sin interfaz de administración ni ruta en el borde.                                                                                                                     |
| Grafana                                      | 3000/tcp              | —         | Tableros, alcanzados por el borde en /grafana/.                                                                                                                                                           |

### 3.4 Aristas permitidas

La tabla reproduce las dieciocho aristas de ADR-014 y añade el mecanismo que impone cada una. Toda comunicación que no figura en ella está prohibida.

**Tabla 12:** Aristas permitidas y mecanismo que las impone.

| # | Origen         | Destino        | Propósito             | Puerto   | Mecanismo                                                |
|---|----------------|----------------|-----------------------|----------|----------------------------------------------------------|
| 1 | Exterior       | Proxy de borde | Toda petición externa | 443 / 80 | Único puerto publicado.                                  |
| 2 | Proxy de borde | Aplicación web | Recursos estáticos    | 8080     | Red <code>red_borde</code> ; ruta por defecto del borde. |
| 3 | Proxy de borde | API Gateway    | Rutas /api/*          | 8080     | Red <code>red_borde</code> ; ruta del borde.             |

*Continúa en la página siguiente*

| #  | Origen                            | Destino                                      | Propósito                                                             | Puerto | Mecanismo                                                                               |
|----|-----------------------------------|----------------------------------------------|-----------------------------------------------------------------------|--------|-----------------------------------------------------------------------------------------|
| 4  | Proxy de borde                    | Grafana (QA)                                 | Rutas<br>/grafana/*                                                   | 3000   | Red <b>red_borde</b> ;<br>ruta del borde solo en QA.                                    |
| 5  | API Gateway                       | Identidad, Institucional, Campañas, Donación | Rutas publicadas<br>/v1/*                                             | 8080   | Tabla de rutas de ADR-007; token revalidado por el servicio.                            |
| 6  | API Gateway                       | Identidad                                    | Claves públicas, canje del token de servicio, entrega de denegaciones | 8080   | Credencial de servicio del gateway; Tabla 13.                                           |
| 7  | Institucional, Campañas, Donación | Identidad                                    | Claves públicas; Donación canjea su token de servicio                 | 8080   | Publicación de claves sin autenticación; canje con credencial propia.                   |
| 8  | Donación                          | Institucional                                | Instituciones y territorios                                           | 8080   | Token del usuario propagado o, en el escalamiento, token de servicio de Donación.       |
| 9  | Donación                          | Campañas                                     | Campaña de una donación y campañas publicadas                         | 8080   | Token del usuario propagado o, en la consulta periódica, token de servicio de Donación. |
| 10 | Campañas                          | Institucional                                | Sede, institución organizadora y jurisdicción                         | 8080   | Token del administrador propagado.                                                      |
| 11 | Institucional                     | Donación                                     | Indicadores agregados y serie de auditoría                            | 8080   | Token del usuario propagado (U5, U6, U7).                                               |
| 12 | Institucional                     | Campañas, Identidad                          | Serie de auditoría                                                    | 8080   | Token del auditor propagado.                                                            |
| 13 | Notificaciones                    | Donación                                     | Bandeja de salida                                                     | 8080   | Token de servicio con sujeto <b>notificaciones</b> ; Tabla 13.                          |
| 14 | Notificaciones                    | Identidad                                    | Tokens de servicio y contactos institucionales                        | 8080   | Credencial y token de servicio de Notificaciones.                                       |
| 15 | Cada servicio con base            | Su PostgreSQL                                | Persistencia                                                          | 5432   | Red de datos propia; rol de servicio.                                                   |
| 16 | Cada trabajo de la base           | Su PostgreSQL                                | Esquema, datos sintéticos, respaldo y restauración                    | 5432   | Red de datos propia; rol de propietario.                                                |

*Continúa en la página siguiente*

| #  | Origen          | Destino                           | Propósito          | Puerto | Mecanismo                                                                                          |
|----|-----------------|-----------------------------------|--------------------|--------|----------------------------------------------------------------------------------------------------|
| 17 | Prometheus (QA) | API Gateway y los cinco servicios | Métricas           | 8081   | Red <code>red_aplicacion</code> ; solo el puerto de gestión figura en la configuración de raspado. |
| 18 | Grafana (QA)    | Prometheus                        | Consulta de series | 9090   | Red <code>red_observabilidad</code> .                                                              |

### 3.5 Autorización de las operaciones internas

Las operaciones con prefijo `/internal/` nunca se enrutan por el gateway. Cada una comprueba el sujeto del token que la invoca y rechaza cualquier otro con la misma respuesta que ante una ruta inexistente.

**Tabla 13:** Operaciones internas y sujetos admitidos.

| Servicio                            | Operación                                                                                        | Quién puede invocarla                                                                    |
|-------------------------------------|--------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------|
| Identidad                           | GET <code>/.well-known/jwks.json</code>                                                          | Cualquier componente de <code>red_aplicacion</code> . Publica solo claves públicas.      |
| Identidad                           | POST <code>/internal/v1/tokens</code>                                                            | Gateway, Donación y Notificaciones, con su credencial de cliente.                        |
| Identidad                           | POST <code>/internal/v1/auditoria/denegaciones</code>                                            | Token de servicio con sujeto <code>gateway</code> .                                      |
| Identidad                           | GET <code>/internal/v1/contactos</code>                                                          | Token de servicio con sujeto <code>notificaciones</code> .                               |
| Donación                            | GET <code>/internal/v1/bandeja</code> ,<br>POST <code>/internal/v1/bandeja/{id}/resultado</code> | Token de servicio con sujeto <code>notificaciones</code> .                               |
| Donación,<br>Campañas,<br>Identidad | GET <code>/internal/v1/auditoria/eventos</code>                                                  | Token de usuario con rol <code>auditor</code> , propagado por el Servicio Institucional. |

### 3.6 Invariantes de la topología

**Tabla 14:** Invariantes de la topología y verificación que los comprueba.

| ID    | Invariante                                                      | Tipo        | Verificación |
|-------|-----------------------------------------------------------------|-------------|--------------|
| IT-01 | Solo el proxy de borde publica puertos al anfitrión.            | Estructural | V-01         |
| IT-02 | Ningún contenedor de las Zonas 1 y 2 comparte red con una base. | Estructural | V-01, V-02   |

*Continúa en la página siguiente*

| ID    | Invariante                                                                                   | Tipo          | Verificación |
|-------|----------------------------------------------------------------------------------------------|---------------|--------------|
| IT-03 | Cada base comparte red solo con su servicio y sus trabajos.                                  | Estructural   | V-01, V-02   |
| IT-04 | Todas las redes, salvo <code>red_borde</code> , son internas.                                | Estructural   | V-01         |
| IT-05 | El gateway no enruta rutas <code>/internal/</code> ni la publicación de claves.              | Configuración | V-04         |
| IT-06 | Cada operación interna rechaza todo sujeto distinto de los de la Tabla 13.                   | Autorización  | V-05         |
| IT-07 | Ningún rol de servicio lee ni escribe en la base de otro servicio.                           | Credencial    | V-03         |
| IT-08 | Toda llamada entre servicios tiene plazo de espera de 3 segundos; el gateway, de 5 segundos. | Configuración | V-06         |

## 4. Cómputo y contenedores

### 4.1 Composición por ambiente

Un único archivo de Compose en `redvital-infra` describe el sistema. El perfil `qa` añade Prometheus y Grafana; sin perfil, la composición es la de Desarrollo.

**Tabla 15:** Contenedores por ambiente.

| #    | Contenedor                                                                                                     | Tipo            | Desarrollo | QA | Reinicio        |
|------|----------------------------------------------------------------------------------------------------------------|-----------------|------------|----|-----------------|
| 1    | <code>borde</code>                                                                                             | Proxy de borde  | ●          | ●  | Salvo detención |
| 2    | <code>web</code>                                                                                               | Aplicación web  | ●          | ●  | Salvo detención |
| 3    | <code>gateway</code>                                                                                           | API Gateway     | ●          | ●  | Salvo detención |
| 4    | <code>identidad</code>                                                                                         | Servicio        | ●          | ●  | Salvo detención |
| 5    | <code>institucional</code>                                                                                     | Servicio        | ●          | ●  | Salvo detención |
| 6    | <code>campanas</code>                                                                                          | Servicio        | ●          | ●  | Salvo detención |
| 7    | <code>donacion</code>                                                                                          | Servicio        | ●          | ●  | Salvo detención |
| 8    | <code>notificaciones</code>                                                                                    | Trabajador      | ●          | ●  | Salvo detención |
| 9–12 | <code>db_identidad</code> , <code>db_institucional</code> , <code>db_campana</code> , <code>db_donacion</code> | Base de datos   | ●          | ●  | Salvo detención |
| 13   | <code>prometheus</code>                                                                                        | Observabilidad  |            | ●  | Salvo detención |
| 14   | <code>grafana</code>                                                                                           | Observabilidad  |            | ●  | Salvo detención |
| —    | <code>migracion_*</code> (cuatro)                                                                              | Trabajo efímero | ●          | ●  | Nunca           |
| —    | <code>respaldo_*</code> , <code>restauracion_*</code>                                                          | Trabajo efímero |            | ●  | Nunca           |

*Continúa en la página siguiente*

| #                          | Contenedor | Tipo | Desarrollo | QA | Reinicio |
|----------------------------|------------|------|------------|----|----------|
| Contenedores de larga vida |            |      | 12         | 14 |          |

Los trabajos de respaldo y de restauración se declaran con un perfil propio y solo se ejecutan bajo demanda o por el programador del anfitrión (Sección 11). La política de reinicio *salvo detención* devuelve a servicio un contenedor caído sin intervención, que es la condición de EC-07.

## 4.2 Orden de arranque

El arranque se encadena por condición y no por orden de declaración (ADR-014). La composición declara, para cada contenedor, la condición de cada dependencia.

**Tabla 16:** Orden de arranque y condición de cada dependencia.

| Paso | Contenedor                              | Espera a                                                                                                  |
|------|-----------------------------------------|-----------------------------------------------------------------------------------------------------------|
| 1    | Cuatro bases                            | Nada. Arrancan en paralelo.                                                                               |
| 2    | migracion_*                             | Su base, sana.                                                                                            |
| 3    | identidad                               | migracion_identidad, terminado con éxito.                                                                 |
| 4    | institucional,<br>campanas,<br>donacion | Su trabajo de migración, terminado con éxito, e identidad, sana.                                          |
| 5    | notificaciones                          | donacion e identidad, sanas.                                                                              |
| 6    | gateway                                 | identidad, institucional, campanas y donacion, sanas.<br>No espera a notificaciones, porque no la enruta. |
| 7    | web                                     | Nada.                                                                                                     |
| 8    | borde                                   | gateway y web, sanos.                                                                                     |
| 9    | prometheus,<br>grafana (QA)             | Nada. Arrancan en paralelo al resto.                                                                      |

Un trabajo de migración que falla detiene el arranque de su servicio, y el registro del trabajo lo muestra separado del registro del servicio: un fallo de esquema no se confunde con un fallo de ejecución.

## 4.3 Sondas de salud

Todas las sondas se declaran en forma de lista de ejecución, de modo que no necesitan intérprete de órdenes dentro del contenedor.

**Tabla 17:** Sondas de salud por contenedor.

| Contenedor                                  | Sonda                                                                                                                                                                                                                               | Intervalo<br>· plazo ·<br>reintentos | Periodo ini-<br>cial |
|---------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------|----------------------|
| Gateway, Identidad, Institucional, Campañas | Programa de sonda de la plantilla común .NET, que consulta <code>http://localhost:8081/salud</code> . En los servicios, <code>/salud</code> comprueba que la base responde; en el gateway, que dispone de claves públicas vigentes. | 15 s · 3 s ·<br>3                    | 30 s                 |
| Donación                                    | Clase de sonda en su propio archivo, ejecutada con la máquina virtual de Java en modo cliente y con 16 MiB de memoria. Consulta <code>/salud</code> en el puerto 8081, que comprueba la base.                                       | 15 s · 3 s ·<br>3                    | 60 s                 |
| Notificaciones                              | Igual que Donación. Su <code>/salud</code> comprueba que alcanza la bandeja de Donación con un token de servicio vigente.                                                                                                           | 15 s · 3 s ·<br>3                    | 60 s                 |
| PostgreSQL                                  | <code>pg_isready</code> contra su propia base.                                                                                                                                                                                      | 10 s · 3 s ·<br>5                    | 20 s                 |
| Proxy de borde, aplicación web              | Petición HTTP local con el cliente incluido en la imagen oficial.                                                                                                                                                                   | 15 s · 3 s ·<br>3                    | 10 s                 |
| Prometheus, Grafana                         | Punto de salud propio de cada producto.                                                                                                                                                                                             | 30 s · 5 s ·<br>3                    | 30 s                 |

#### 4.4 Presupuesto de recursos

Los límites se fijan como presupuesto de diseño y se declaran para cada contenedor. Cumplen dos funciones: impiden que un contenedor agote el anfitrión y convierten un exceso de consumo en un reinicio visible en lugar de una degradación silenciosa. La medición de consumo en reposo y bajo carga (T-411, EC-26) los confirma o los corrige en una versión posterior de este documento, con registro del ajuste.

**Tabla 18:** Presupuesto de memoria y CPU por contenedor.

| Contenedor                         | Memoria        | CPU      | Configuración asociada                                             |
|------------------------------------|----------------|----------|--------------------------------------------------------------------|
| Proxy de borde                     | 128 MiB        | 0,50     | —                                                                  |
| Aplicación web                     | 64 MiB         | 0,25     | —                                                                  |
| API Gateway                        | 256 MiB        | 1,00     | El recolector de memoria de .NET respeta el límite del contenedor. |
| Identidad, Institucional, Campañas | 384 MiB<br>c/u | 0,75 c/u | Grupo de conexiones a la base con un máximo de 20.                 |

*Continúa en la página siguiente*

| Contenedor                                 | Memoria          | CPU      | Configuración asociada                                                            |
|--------------------------------------------|------------------|----------|-----------------------------------------------------------------------------------|
| Donación                                   | 768 MiB          | 1,50     | Montículo de Java al 70 % del límite.<br>Grupo de conexiones con un máximo de 20. |
| Notificaciones                             | 384 MiB          | 0,50     | Montículo de Java al 70 % del límite.                                             |
| db_identidad, db_institucional, db_campana | 256 MiB<br>c/u   | 0,50 c/u | Máximo de 50 conexiones; memoria compartida de 64 MiB.                            |
| db_donacion                                | 384 MiB          | 1,00     | Máximo de 50 conexiones; memoria compartida de 96 MiB.                            |
| Prometheus (QA)                            | 384 MiB          | 0,50     | Retención de 15 días.                                                             |
| Grafana (QA)                               | 256 MiB          | 0,25     | —                                                                                 |
| Trabajos efímeros                          | 256 MiB<br>c/u   | 0,50 c/u | Solo durante su ejecución.                                                        |
| <b>Desarrollo (12)</b>                     | <b>3.904 MiB</b> | 8,50     | Suma de límites.                                                                  |
| <b>QA (14)</b>                             | <b>4.544 MiB</b> | 9,25     | Suma de límites.                                                                  |

**Lectura del presupuesto.** La suma de límites de CPU supera los núcleos del anfitrión a propósito: un límite de CPU recorta, no reserva, y los contenedores no alcanzan su techo a la vez. La memoria no admite esa lógica, porque un exceso termina el proceso, y por eso su suma es la base del requisito de la máquina. El grupo de veinte conexiones de cada servicio queda por debajo del 80 % de las cincuenta que admite su base, que es la condición de EC-26.

## 4.5 Requisitos de los anfitriones

**Tabla 19:** Requisitos mínimos de los anfitriones.

| Recurso | Máquina virtual de QA                                                                                                                         | Equipo de un integrante (Desarrollo)                                                                                   |
|---------|-----------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------|
| Memoria | 8 GiB: los 4.544 MiB de límites de QA, un margen del 50 % para el pico de EC-16 y 1 GiB para el sistema operativo y el motor de contenedores. | 8 GiB como mínimo; los 3.904 MiB de límites de Desarrollo dejan espacio para un entorno de desarrollo abierto (EC-27). |
| CPU     | 4 núcleos virtuales.                                                                                                                          | 4 núcleos.                                                                                                             |
| Disco   | 40 GB: imágenes, volúmenes de las cuatro bases, series de Prometheus y 14 días de respaldos.                                                  | 20 GB libres.                                                                                                          |
| Sistema | Ubuntu Server 24.04 LTS, Docker Engine y Compose v2, sincronización de hora del anfitrión activa.                                             | Windows, macOS o Linux con Docker Desktop o Docker Engine y Compose v2.                                                |

*Continúa en la página siguiente*

| Recurso | Máquina virtual de QA                                                                                                                                  | Equipo de un integrante (Desarrollo) |
|---------|--------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------|
| Red     | Alcanzable desde fuera de la red de la universidad en los puertos 443 y 80. Puerto 22 solo desde las direcciones de administración que declara DevOps. | Sin requisitos.                      |

## 4.6 Reglas comunes de ejecución

- **Hora.** Todos los contenedores operan en tiempo universal coordinado. La bitácora de auditoría ordena los eventos de las cuatro series por marca temporal (ADR-016), y esa composición solo es correcta si ningún componente escribe en hora local.
- **Registros.** Todo componente escribe registros estructurados en JSON por la salida estándar. El motor de contenedores los conserva con rotación: tres archivos de 10 MB por contenedor. Sin rotación, un contenedor ruidoso llena el disco del anfitrión y detiene a todos los demás.
- **Configuración.** Toda configuración entra por variable de entorno y todo secreto, por archivo montado en `/run/secrets`. La Sección 12 lista las variables.
- **Escalado.** El gateway y el Servicio de Donación no guardan estado en memoria que no pueda perderse, de modo que admiten una segunda réplica con la orden de escalado de réplicas de Compose. Los procesos programados de Donación toman un bloqueo en su base antes de cada ciclo, de modo que una sola réplica lo ejecuta (EC-37).

## 5. Imágenes y endurecimiento

### 5.1 Imágenes por componente

Toda imagen propia se construye en dos etapas: una de construcción con el kit completo de la plataforma y otra de ejecución que solo contiene el entorno de ejecución y el artefacto. Toda imagen base se fija por versión completa y por resumen criptográfico; nunca por etiqueta móvil.

**Tabla 20:** Imágenes de construcción y de ejecución por componente.

| Componente                                  | Construcción   | Ejecución                                                                                                                                                                                                        |
|---------------------------------------------|----------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Gateway, Identidad, Institucional, Campañas | SDK de .NET 10 | ASP.NET Core 10 en su variante <i>chiseled</i> sobre Ubuntu 24.04: sin intérprete de órdenes ni gestor de paquetes, con usuario no privilegiado por defecto. Incluye el programa de sonda de la plantilla común. |

*Continúa en la página siguiente*

| Componente               | Construcción                                                                                                                                                        | Ejecución                                                                                                                                                              |
|--------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Donación, Notificaciones | Eclipse Temurin 25 JDK y Maven. Un entorno de ejecución reducido se genera con <code>jlink</code> a partir de Temurin 25, solo con los módulos que el servicio usa. | Distroless base de Debian 13 en su variante no privilegiada, con el entorno reducido de Temurin 25 copiado: sin intérprete de órdenes ni gestor de paquetes (ADR-009). |
| Aplicación web           | Node.js 24 y Vite 6                                                                                                                                                 | Imagen oficial de Caddy 2 como servidor de archivos, con los recursos compilados y sin la configuración de borde.                                                      |
| Proxy de borde           | —                                                                                                                                                                   | Imagen oficial de Caddy 2, sin módulos adicionales (ADR-015).                                                                                                          |
| PostgreSQL               | —                                                                                                                                                                   | Imagen oficial de PostgreSQL 16.                                                                                                                                       |
| Trabajos de migración    | SDK de .NET 10 o Temurin 25 y Maven                                                                                                                                 | Imagen de ejecución de su plataforma con las migraciones versionadas; los de respaldo y restauración usan la imagen oficial de PostgreSQL 16.                          |
| Prometheus, Grafana      | —                                                                                                                                                                   | Imágenes oficiales.                                                                                                                                                    |

**Imágenes propias e imágenes de terceros.** La ausencia de intérprete de órdenes es obligatoria en las seis imágenes de ejecución que construye el equipo para sus servicios y el gateway. Las imágenes oficiales de Caddy, PostgreSQL, Prometheus y Grafana se usan tal como las publica su proyecto, porque reconstruirlas convertiría al equipo en mantenedor de cuatro productos ajenos. Sobre ellas se aplican el resto de controles de la Tabla 21, el escaneo de vulnerabilidades y la fijación por resumen, y la presencia de su intérprete de órdenes queda registrada como riesgo aceptado (Sección 13).

## 5.2 Endurecimiento de contenedores

**Tabla 21:** Controles de endurecimiento de contenedores.

| Control                             | Configuración                                                                         | Alcance                                                                                                                                                                     |
|-------------------------------------|---------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Usuario no privilegiado             | Usuario con identificador distinto de 0 declarado en la imagen y en la composición.   | Todos. PostgreSQL corre con el usuario <code>postgres</code> de su imagen desde el primer arranque.                                                                         |
| Sistema de archivos de solo lectura | Raíz de solo lectura; escritura solo en volúmenes y en <code>tmpfs</code> declarados. | Todos. Las rutas escribibles son el volumen de datos de cada base y de Prometheus y Grafana, el volumen de datos del borde y un <code>tmpfs</code> para <code>/tmp</code> . |
| Capacidades del núcleo              | Todas retiradas; ninguna añadida.                                                     | Todos. El borde no necesita la de enlace a puertos privilegiados porque escucha en 8443 y 8080.                                                                             |

*Continúa en la página siguiente*

| Control                 | Configuración                                                      | Alcance                                           |
|-------------------------|--------------------------------------------------------------------|---------------------------------------------------|
| Escalada de privilegios | Prohibida con la opción <code>no-new-privileges</code> .           | Todos.                                            |
| Límites de recursos     | Memoria y CPU de la Tabla 18.                                      | Todos, incluidos los trabajos efímeros.           |
| Puertos                 | Ninguno publicado salvo los del borde.                             | Todos.                                            |
| Intérprete de órdenes   | Ausente en la imagen de ejecución.                                 | Las seis imágenes propias de servicios y gateway. |
| Contenido de la imagen  | Sin compiladores, gestores de paquetes, código fuente ni secretos. | Todas las imágenes propias.                       |

El Anexo A muestra la declaración de un servicio con todos estos controles.

## 6. Almacenamiento y datos

### 6.1 Bases y volúmenes

**Tabla 22:** Bases de datos, propietario y volumen.

| Base                          | Servicio propietario | Volumen y contenido                                                                                                                    |
|-------------------------------|----------------------|----------------------------------------------------------------------------------------------------------------------------------------|
| <code>db_identidad</code>     | Identidad            | <code>vol_db_identidad</code> . Usuarios, roles, jurisdicciones asignadas, sesiones, credenciales de servicio y su serie de auditoría. |
| <code>db_institucional</code> | Institucional        | <code>vol_db_institucional</code> . Territorios, instituciones y su serie de auditoría.                                                |
| <code>db_campana</code>       | Campañas             | <code>vol_db_campana</code> . Campañas, reservas de cupo y su serie de auditoría.                                                      |
| <code>db_donacion</code>      | Donación             | <code>vol_db_donacion</code> . Las veintidós entidades del ciclo de vida, la bandeja de salida y su serie de auditoría.                |

En Desarrollo los volúmenes pueden borrarse en cualquier momento: los trabajos de migración reconstruyen el esquema y los datos sintéticos en el siguiente arranque. En QA los volúmenes son persistentes y se respaldan.

### 6.2 Roles de base de datos

Cada base tiene tres roles, y cada rol tiene un único usuario.

**Tabla 23:** Roles de cada base y privilegios.

| Rol                                  | Quién lo usa                                                                              | Privilegios                                                                                                                                                              |
|--------------------------------------|-------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Superusuario                         | El guion de inicialización de la imagen de PostgreSQL, una sola vez, al crear el volumen. | Crea los otros dos roles y el esquema vacío. Ningún servicio ni trabajo conoce su credencial.                                                                            |
| Propietario (<contexto>_propietario) | El trabajo de migración y los de respaldo y restauración de esa base.                     | Dueño del esquema: define datos y carga el conjunto sintético. No puede conectarse a otra base.                                                                          |
| Servicio (<contexto>_servicio)       | El servicio propietario.                                                                  | Consulta, inserción, actualización y borrado sobre las tablas de su esquema, sin definición de datos. Sobre las tablas de solo anexado, únicamente consulta e inserción. |

**Tablas de solo anexado.** La restricción que EC-04 y EC-05 exigen a la aplicación —cero operaciones de modificación o borrado sobre el historial y la bitácora— se impone también en la base, retirando al rol de servicio los privilegios de actualización y borrado sobre estas tablas:

- db\_donacion: evento\_unidad y registro\_auditoria.
- db\_institucional: registro\_auditoria\_inst.
- db\_campana: registro\_auditoria\_camp.
- db\_identidad: registro\_auditoria\_ident.

Un defecto del código que intente modificar una de ellas falla en la base, aunque haya pasado la revisión.

### 6.3 Aislamiento y comprobación

El aislamiento entre bases tiene dos capas independientes. La primera es de red: un servicio no comparte red con la base de otro, y por tanto no puede abrir la conexión. La segunda es de credencial: aun dentro de la red de una base, el rol de servicio de otro contexto no existe en ella y la autenticación falla. V-02 comprueba la primera y V-03 la segunda.

## 7. Seguridad y accesos

### 7.1 Defensa en capas

Una petición externa atraviesa cuatro controles independientes antes de tocar un dato, y ninguno supone que el anterior ya actuó.

**Tabla 24:** Capas de control de una petición externa.

| Capa       | Componente           | Qué decide                                                                                                             |
|------------|----------------------|------------------------------------------------------------------------------------------------------------------------|
| Transporte | Proxy de borde       | Si la conexión es TLS válida, si el cuerpo cabe en 1 MiB y a qué destino va la ruta. No conoce el dominio ni el token. |
| Entrada    | API Gateway          | Si el token es auténtico y vigente, si el rol puede usar esa ruta y si el llamador excede su tasa.                     |
| Recurso    | Servicio propietario | Si el token es auténtico —lo valida de nuevo—, y si el recurso concreto está dentro de la jurisdicción del usuario.    |
| Dato       | Base de datos        | Si el rol que se conecta puede tocar esa tabla con esa operación.                                                      |

El Servicio de Identidad no está en el camino de cada petición: emite los tokens y publica las claves públicas, y el gateway y los servicios validan sin consultarlo (ADR-008). Si Identidad cae, las peticiones con token vigente se siguen atendiendo durante un máximo de quince minutos.

## 7.2 Borde

La configuración del borde vive en un único archivo de **redvital-infra**, idéntico en los tres ambientes salvo por las variables de dominio y de emisor de certificados. El Anexo B lo reproduce.

**Tabla 25:** Configuración del proxy de borde.

| Elemento                | Configuración                                                                                                                                                                                                                                                                                                                                   |
|-------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| TLS                     | Versiones 1.2 y 1.3. En Desarrollo y QA, certificado emitido por la autoridad interna de Caddy; en Producción, por ACME (ADR-015).                                                                                                                                                                                                              |
| Autoridad interna de QA | Su clave raíz se conserva en el volumen persistente <b>vol_borde_datos</b> y se respalda con las bases. Si el volumen se perdiera, el borde generaría una raíz nueva y el certificado que se entregó al cliente evaluador dejaría de servir. El certificado raíz —nunca la clave— se entrega al evaluador junto con la dirección de la máquina. |
| Redirección             | Toda petición HTTP en el puerto 80 recibe una redirección permanente a HTTPS.                                                                                                                                                                                                                                                                   |
| Cabeceras de respuesta  | <b>Strict-Transport-Security</b> de un año;<br><b>Content-Security-Policy</b> restringida al propio origen con <b>frame-ancestors 'none'</b> ; <b>X-Content-Type-Options: nosniff</b> ;<br><b>Referrer-Policy: no-referrer</b> ; <b>Permissions-Policy</b> sin cámara, micrófono ni ubicación. Se retira la cabecera <b>Server</b> .            |
| Cabeceras de entrada    | Se descartan las cabeceras <b>X-Forwarded-*</b> que envía el cliente y se añaden las propias. El gateway solo confía en <b>X-Forwarded-For</b> cuando la conexión viene del borde.                                                                                                                                                              |

*Continúa en la página siguiente*

| Elemento           | Configuración                                                                                                            |
|--------------------|--------------------------------------------------------------------------------------------------------------------------|
| Cuerpo             | Máximo de 1 MiB en <code>/api/*</code> ; el exceso recibe 413 sin llegar al gateway.                                     |
| Encaminamiento     | <code>/api/*</code> al gateway; <code>/grafana/*</code> a Grafana, solo en QA; cualquier otra ruta, a la aplicación web. |
| Registro de acceso | JSON, con <code>Authorization</code> y las cookies redactadas. Nunca registra el cuerpo.                                 |
| Administración     | Interfaz de administración de Caddy deshabilitada: la configuración cambia solo por redesplicue.                         |
| Límite de tasa     | Ninguno en el borde. Pertenece al gateway (ADR-007, ADR-015).                                                            |

### 7.3 Autenticación entre componentes

- **Petición de un usuario.** El gateway valida el token y lo reenvía; cada servicio lo valida de nuevo. Cuando un servicio necesita a otro para atender esa petición, propaga el token del usuario, y el servicio llamado aplica la autorización del usuario original.
- **Proceso sin usuario.** El gateway al entregar denegaciones, el Servicio de Donación en sus procesos programados y el trabajador de Notificaciones canjean su credencial de cliente por un token de servicio de quince minutos, con rol `servicio` y su nombre como sujeto. Un token de servicio se rechaza en toda ruta de usuario.
- **Publicación de claves.** Identidad publica sus claves públicas en `/.well-known/jwks.json`, alcanzable solo en `red_aplicacion`. Cada validador las guarda diez minutos y las vuelve a pedir ante un identificador de clave desconocido, como máximo una vez cada treinta segundos. Sin claves, rechaza toda petición que exige sesión.
- **Tráfico dentro del anfitrión.** Dentro de las redes internas el tráfico es HTTP sin cifrar. La integridad de la autorización no depende del transporte, porque los tokens van firmados; la confidencialidad del tráfico interno descansa en que esas redes no salen del anfitrión. La topología de Producción añade TLS mutuo entre servicios (Sección 12.4).

### 7.4 Inventario de secretos

Ningún secreto está en un repositorio, en una imagen ni en el archivo de orquestación. Cada contenedor recibe como archivo en `/run/secrets` solo los secretos que usa.

**Tabla 26:** Inventario de secretos, custodio, origen y rotación.

| Secreto                                                            | Lo lee                                                     | Origen                                                                                                                                                                                                                                 | Rotación                                                                                               |
|--------------------------------------------------------------------|------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------|
| Clave privada de firma del token                                   | Identidad                                                  | Desarrollo: generada una vez por el guion de inicialización de <b>redvital-infra</b> en un directorio excluido del control de versiones. QA: secreto de Compose legible solo por el usuario de despliegue. Producción: gestor externo. | Ordinaria al inicio de cada sprint en QA; de emergencia ante compromiso.                               |
| Credencial de cliente del gateway, de Donación y de Notificaciones | Cada uno la suya                                           | Generadas por el guion de inicialización. Identidad recibe solo sus resúmenes, que carga su trabajo de migración.                                                                                                                      | Ante exposición y al retirarse un integrante con acceso a QA.                                          |
| Credencial del superusuario de cada base                           | Su contenedor PostgreSQL                                   | Generada por el guion de inicialización.                                                                                                                                                                                               | Se regenera al recrear el volumen.                                                                     |
| Credencial del rol de propietario de cada base                     | Trabajos de migración, respaldo y restauración de esa base | Generada por el guion de inicialización.                                                                                                                                                                                               | Ante exposición y al retirarse un integrante con acceso a QA.                                          |
| Credencial del rol de servicio de cada base                        | Su servicio                                                | Generada por el guion de inicialización.                                                                                                                                                                                               | Ante exposición y al retirarse un integrante con acceso a QA.                                          |
| Clave de la autenticidad interna del borde                         | Borde                                                      | Generada por Caddy en su primer arranque y conservada en <code>vol_borde_datos</code> .                                                                                                                                                | Se conserva durante todo el proyecto en QA, para que el certificado raíz entregado siga siendo válido. |
| Contraseña de administración de Grafana                            | Grafana (QA)                                               | Secreto de Compose.                                                                                                                                                                                                                    | Al inicio de cada sprint.                                                                              |
| Token de lectura del registro de imágenes                          | Motor de contenedores de la máquina de QA                  | Token de la organización con permiso solo de lectura de paquetes.                                                                                                                                                                      | Al inicio de cada sprint.                                                                              |
| Permiso de publicación de imágenes                                 | Flujos de integración continua sobre <code>main</code>     | Token efímero que la plataforma emite para cada ejecución.                                                                                                                                                                             | No existe secreto de larga vida.                                                                       |

*Continúa en la página siguiente*

| Secreto                      | Lo lee                         | Origen                                                                                      | Rotación                    |
|------------------------------|--------------------------------|---------------------------------------------------------------------------------------------|-----------------------------|
| Claves SSH de administración | DevOps y un suplente designado | Clave pública autorizada en la máquina de QA; la privada nunca sale del equipo de su dueño. | Al retirarse un integrante. |

## 7.5 Rotación de la clave de firma

**Ordinaria**, al inicio de cada sprint en QA (ADR-008):

1. DevOps genera un par nuevo con un identificador de clave nuevo y lo entrega a Identidad como secreto adicional.
2. Identidad se redespiega y publica la clave pública nueva junto a la vigente. Sigue firmando con la vigente.
3. Pasados diez minutos —la vigencia de la caché de claves de los validadores—, Identidad pasa a firmar con la nueva mediante su variable de clave activa.
4. La clave pública anterior sigue publicada una hora más, holgura sobre los quince minutos de vida de un token, y luego se retira junto con su secreto.

Ninguna sesión se invalida. La evidencia es una sesión iniciada antes del paso 1 que sigue renovándose después del paso 4 (V-12).

**De emergencia**, ante compromiso de la clave: se retira de inmediato la clave comprometida, Identidad revoca todas las sesiones de renovación, y el gateway y los servicios se reinician para vaciar su caché de claves, de modo que ningún token firmado con la clave comprometida se acepta un minuto más. Los usuarios inician sesión de nuevo.

## 7.6 Acceso administrativo a la máquina de QA

- Solo por SSH con clave, sin contraseña y sin acceso directo del usuario administrador del sistema.
- Solo DevOps y un suplente designado por el Scrum Master pertenecen al grupo que controla el motor de contenedores, porque ese grupo equivale a administrador del anfitrión.
- El cortafuegos del anfitrión admite 443 y 80 desde cualquier origen y 22 solo desde las direcciones de administración declaradas. El motor de contenedores no publica ningún otro puerto, porque ningún otro contenedor lo declara.
- El despliegue lo ejecuta un usuario de despliegue sin acceso interactivo, dueño de los archivos de secretos, con permiso de lectura solo para él.

## 8. Modelo de amenazas

El modelo recorre las seis categorías STRIDE en cada una de las cinco fronteras de la Tabla 9: treinta celdas. Cada amenaza es concreta de RedVital y tiene un control con su verificación, o un riesgo aceptado declarado en la Sección 13.

**Tabla 27:** Modelo de amenazas por frontera y categoría STRIDE.

| ID                                                 | C. | Amenaza                                                                                                                        | Control                                                                                                                                                       | Verificación         |
|----------------------------------------------------|----|--------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------|----------------------|
| <b>F1 · Exterior ↔ Zona 1</b>                      |    |                                                                                                                                |                                                                                                                                                               |                      |
| F1-S                                               | S  | Un tercero suplanta el sitio e intercepta credenciales.                                                                        | TLS 1.2 y 1.3 con certificado cuya raíz recibe el evaluador; HSTS de un año.                                                                                  | V-08                 |
| F1-T                                               | T  | Manipulación en tránsito, o cabeceras <b>X-Forwarded-*</b> forjadas para falsear el origen y evadir el límite por origen.      | TLS; el borde descarta las cabeceras de reenvío del cliente y el gateway solo las acepta del borde.                                                           | V-08, EC-06          |
| F1-R                                               | R  | Un cliente niega haber enviado una petición.                                                                                   | Registro de acceso JSON del borde con marca temporal, origen, ruta y estado, primer eslabón de la traza de EC-20.                                             | RIF-05               |
| F1-I                                               | I  | Fuga de información por la cabecera <b>Server</b> , por páginas de error o por credenciales escritas en el registro de acceso. | Cabecera <b>Server</b> retirada; redacción de <b>Authorization</b> y cookies; ningún cuerpo registrado.                                                       | V-08                 |
| F1-D                                               | D  | Inundación de peticiones o cuerpos desmedidos.                                                                                 | Cuerpo máximo de 1 MiB en el borde; límite de tasa en el gateway antes de enrutar; límites de recursos por contenedor.                                        | EC-06, EC-37, RIF-04 |
| F1-E                                               | E  | Acceso desde fuera a la administración de Caddy, a Prometheus o a Grafana sin sesión.                                          | Administración de Caddy deshabilitada; Prometheus sin ruta; Grafana solo en QA, con inicio de sesión y acceso anónimo deshabilitado.                          | V-01, V-15           |
| <b>F2 · Zona 1 ↔ Zona 2</b>                        |    |                                                                                                                                |                                                                                                                                                               |                      |
| F2-S                                               | S  | Token fabricado, firmado por otro emisor o con otra audiencia.                                                                 | Validación de firma RS256, emisor, audiencia y vencimiento; rechazo con 503 sin claves públicas.                                                              | EC-03                |
| F2-T                                               | T  | Alteración del rol o de la jurisdicción dentro del token.                                                                      | La firma cubre todas las reivindicaciones; cada servicio revalida.                                                                                            | EC-03                |
| F2-R                                               | R  | Un usuario niega un intento de acceso denegado.                                                                                | Denegación entregada a la serie de auditoría de Identidad con correlación; contador de las no entregadas.                                                     | EC-01, EC-05, V-16   |
| F2-I                                               | I  | Enumeración de códigos de intención o de identificadores, o una respuesta que confirma la existencia de un recurso ajeno.      | Límite de 60 peticiones por minuto y origen en las rutas públicas; identificadores no secuenciales; respuesta indistinguible de la de un recurso inexistente. | EC-06, EC-01         |
| F2-D                                               | D  | Abuso automatizado del registro anónimo o del inicio de sesión.                                                                | Escala anónima por origen y escala autenticada por sesión, con 429 antes de enrutar.                                                                          | EC-06, RIF-04        |
| F2-E                                               | E  | Acceso desde fuera a operaciones internas o a rutas de otro rol.                                                               | El gateway nunca enruta <b>/internal/</b> ni la publicación de claves; compuerta por ruta y rol derivada de ADR-011.                                          | V-04, EC-01          |
| <b>F3 · Zona 2 ↔ Zona 3, y dentro de la Zona 3</b> |    |                                                                                                                                |                                                                                                                                                               |                      |

*Continúa en la página siguiente*

| ID                          | C. | Amenaza                                                                                                                        | Control                                                                                                                                | Verificación       |
|-----------------------------|----|--------------------------------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------|--------------------|
| F3-S                        | S  | Un componente de <b>red_aplicacion</b> invoca una operación interna haciéndose pasar por otro.                                 | Credencial de cliente por componente; cada operación interna acepta solo los sujetos de la Tabla 13.                                   | V-05               |
| F3-T                        | T  | Alteración de una petición entre servicios dentro de la red interna.                                                           | Tokens firmados; redes internas sin salida del anfitrión.                                                                              | RIF-01             |
| F3-R                        | R  | Una acción automática queda atribuida a un usuario, o un servicio niega haberla ejecutado.                                     | Actor <i>sistema</i> con el sujeto del token de servicio en la bitácora del servicio que actúa.                                        | EC-33              |
| F3-I                        | I  | Un servicio devuelve datos fuera de jurisdicción o un contrato interno expone contenido de recursos o causa clínica.           | Filtrado por jurisdicción en cada servicio; los contratos de auditoría devuelven solo la estructura común; RI-02.                      | EC-01, EC-02       |
| F3-D                        | D  | Un servicio lento arrastra a quienes lo consultan.                                                                             | Plazo de 3 segundos entre servicios y de 5 segundos del gateway; límites de recursos; degradación declarada.                           | EC-08, V-06        |
| F3-E                        | E  | Uso de un token de servicio en una ruta de usuario, o de un token de usuario para una operación interna reservada a servicios. | Rechazo del rol <b>servicio</b> en rutas de usuario; operaciones internas atadas a sujetos concretos.                                  | EC-03, V-05        |
| <b>F4 · Zona 3 ↔ Zona 4</b> |    |                                                                                                                                |                                                                                                                                        |                    |
| F4-S                        | S  | Un servicio se conecta con credenciales de otro contexto.                                                                      | Red de datos por base; roles distintos por base.                                                                                       | V-02, V-03         |
| F4-T                        | T  | Modificación o borrado del historial de una unidad o de la bitácora.                                                           | Rol de servicio sin actualización ni borrado sobre las tablas de solo anexo.                                                           | V-07, EC-04, EC-05 |
| F4-R                        | R  | Un cambio de estado queda sin rastro.                                                                                          | El evento de trazabilidad y el de auditoría se insertan en la misma transacción que el cambio.                                         | EC-05              |
| F4-I                        | I  | Lectura del esquema de otra base, o fuga de un respaldo.                                                                       | Aislamiento por red y credencial; respaldos fuera de los contenedores, legibles solo por el usuario de despliegue.                     | V-02, V-03, RIF-06 |
| F4-D                        | D  | Agotamiento de las conexiones de una base.                                                                                     | Grupo de 20 conexiones por servicio frente a 50 admitidas por base.                                                                    | EC-26              |
| F4-E                        | E  | Un servicio define o altera esquema, o usa un superusuario.                                                                    | Rol de servicio sin definición de datos; rol de propietario solo en los trabajos; superusuario solo en la inicialización.              | V-07               |
| <b>F5 · Zona 3 ↔ Zona 5</b> |    |                                                                                                                                |                                                                                                                                        |                    |
| F5-S                        | S  | Una fuente falsa de métricas contamina la medición de un escenario.                                                            | Prometheus raspa solo los destinos declarados por nombre en su configuración.                                                          | RIF-07             |
| F5-T                        | T  | Manipulación de las métricas en tránsito.                                                                                      | Red interna sin salida del anfitrión.                                                                                                  | RIF-07             |
| F5-R                        | R  | Un tablero o una alerta cambia sin autor identificable.                                                                        | Tableros y alertas versionados en <b>redvital-infra</b> y aprovisionados como archivos de solo lectura; usuarios nominales en Grafana. | V-15               |

Continúa en la página siguiente

| ID   | C. | Amenaza                                                                                     | Control                                                                                                                        | Verificación |
|------|----|---------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------|--------------|
| F5-I | I  | Etiquetas de métricas o registros con datos personales, causa clínica o contenido de token. | Etiquetas acotadas a ruta, método, código de estado y servicio; nunca identificadores de usuario, donante ni unidad; RN-01.    | V-14, EC-20  |
| F5-D | D  | Explosión de cardinalidad que agota Prometheus.                                             | Etiquetas acotadas; retención de 15 días; límite de memoria.                                                                   | V-14         |
| F5-E | E  | Acceso de administración a Grafana o a Prometheus.                                          | Acceso anónimo deshabilitado; evaluador con rol de solo lectura; Prometheus sin ruta externa y sin interfaz de administración. | V-15         |

## 9. Integración continua como control

### 9.1 Etapas por repositorio

**Tabla 28:** Etapas de la integración continua por tipo de repositorio.

| Repositorio                        | Etapas en cada Pull Request                                                                                                                                                                                                              |
|------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Servicios, gateway, aplicación web | Compilación, análisis estático, pruebas, detección de secretos, construcción de la imagen y escaneo de vulnerabilidades. Al fusionar en <code>main</code> , publicación de la imagen con su versión y el identificador corto del commit. |
| <code>redvital-infra</code>        | Detección de secretos, validación del archivo de orquestación y comprobación estática de los invariantes IT-01 a IT-04 sobre la composición resuelta (V-01).                                                                             |
| <code>redvital-docs</code>         | Detección de secretos.                                                                                                                                                                                                                   |

### 9.2 Detección de secretos

Gitleaks se ejecuta como binario de línea de órdenes, fijado por versión y verificado por suma de comprobación, sobre el conjunto de cambios de cada Pull Request y sobre el historial completo al fusionar en `main`. Un hallazgo bloquea la fusión. Un falso positivo se admite solo con una entrada en el archivo de excepciones del repositorio, revisada en el mismo Pull Request.

### 9.3 Escaneo de imágenes

Grype se ejecuta sobre la imagen construida, fijado por versión y verificado por suma de comprobación. La construcción falla ante cualquier vulnerabilidad de severidad alta o crítica que tenga corrección publicada. Una vulnerabilidad sin corrección publicada no bloquea, pero queda como historia en el backlog con su identificador. Las imágenes de terceros se escanean en el flujo de `redvital-infra` con el mismo umbral.

### 9.4 Cadena de suministro de la integración continua

- Toda acción de terceros se fija por el identificador completo de su commit, nunca por etiqueta.
- El permiso del token de cada flujo es de solo lectura por defecto. Solo el trabajo de publicación, sobre `main`, recibe permiso de escritura de paquetes.

- Los flujos de Pull Request no reciben ningún secreto de despliegue.
- `main` y `develop` están protegidas: fusión solo por Pull Request aprobado por alguien distinto del autor y con todas las etapas en verde.

## 10. Observabilidad

### 10.1 Métricas

Prometheus existe solo en QA. Raspa cada quince segundos el punto `/metrics` del puerto de gestión del gateway y de los cinco servicios, declarados por nombre en su configuración, y conserva las series quince días. En Desarrollo la instrumentación existe y el punto responde, pero no se ejecuta recolector.

**Tabla 29:** Métricas mínimas y escenario que sostienen.

| Métrica                                                 | Origen                | Sostiene                                                                |
|---------------------------------------------------------|-----------------------|-------------------------------------------------------------------------|
| Duración de las peticiones por ruta, en histograma      | Gateway               | EC-15, EC-16 y EC-37: percentiles medidos donde los percibe el usuario. |
| Peticiones por ruta y código de estado                  | Gateway y servicios   | Tasa de error de EC-16; rechazos 429 y 503 de EC-06 y EC-37.            |
| Estado del sondeo de salud                              | Gateway y servicios   | Disponibilidad de EC-07.                                                |
| Uso de CPU y memoria por contenedor                     | Motor de contenedores | EC-16, EC-26 y EC-37.                                                   |
| Conexiones en uso por grupo                             | Servicios con base    | EC-26.                                                                  |
| Accesos denegados por jurisdicción                      | Gateway y servicios   | Evidencia cuantitativa de RNF-02.                                       |
| <code>auditoria_denegaciones_no_entregadas_total</code> | Gateway               | Integridad de la bitácora (ADR-016).                                    |
| Eventos de la bandeja por estado                        | Donación              | EC-11.                                                                  |

**Regla de etiquetas.** Una etiqueta de métrica solo puede tomar valores de un conjunto acotado: servicio, ruta como plantilla, método, código de estado, estado de la bandeja y jurisdicción de nivel departamental. Nunca identificadores de usuario, donante, unidad, token ni texto libre. La regla protege a la vez la confidencialidad (RN-01) y la memoria de Prometheus.

### 10.2 Tableros y alertas

Grafana solo existe en QA y solo se alcanza por el borde en `/grafana/`. El origen de datos y los tableros se aprovisionan como archivos versionados en `redvital-infra` y quedan de solo lectura en la interfaz: un cambio de tablero es un Pull Request. El acceso anónimo está deshabilitado; cada integrante tiene usuario nominal y el cliente evaluador, un usuario de solo lectura.

**Tabla 30:** Alertas de QA.

| Alerta                     | Condición                                       | Acción                                                                              |
|----------------------------|-------------------------------------------------|-------------------------------------------------------------------------------------|
| Servicio no sano           | Sondeo fallido durante más de 60 segundos.      | DevOps revisa el registro del contenedor por su identificador de correlación.       |
| Denegaciones no entregadas | Contador mayor que cero.                        | Revisión de la disponibilidad de Identidad y del registro estructurado del gateway. |
| Errores del servidor       | Más del 1 % de respuestas 5xx en cinco minutos. | Diagnóstico conforme a EC-20.                                                       |
| Bandeja retenida           | Eventos en revisión manual.                     | Revisión del canal de salida.                                                       |

### 10.3 Registros

Cada componente escribe registros JSON por la salida estándar, con marca temporal en tiempo universal coordinado, nivel, componente e identificador de correlación. El gateway genera el identificador cuando la petición no lo trae y cada servicio lo propaga en toda llamada. Los registros se consultan por contenedor y se correlacionan por ese identificador. Ningún registro contiene cuerpos de petición, tokens, cookies, datos personales ni causa clínica.

## 11. Respaldo, despliegue y recuperación

### 11.1 Respaldo

**Tabla 31:** Política de respaldo de QA.

| Elemento        | Política                                                                                                                                                                                                             |
|-----------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Qué se respalda | Las cuatro bases, cada una por separado, y el volumen de datos del borde, que conserva la autoridad interna de QA.                                                                                                   |
| Cuándo          | Diariamente a las 07:00 en tiempo universal coordinado, las 02:00 en Bogotá, por el programador de tareas del anfitrión; y bajo demanda antes de todo despliegue.                                                    |
| Cómo            | Un trabajo <code>respaldo_&lt;base&gt;</code> por base, con la imagen oficial de PostgreSQL 16, conectado solo a la red de su base con el rol de propietario. Ejecuta <code>pg_dump</code> en formato personalizado. |
| Manifiesto      | Junto a cada respaldo, un manifiesto con la versión de esquema según el historial de migraciones, el número de filas de cada tabla y la suma SHA-256 del archivo.                                                    |
| Dónde           | Directorio del anfitrión fuera de todo volumen de contenedor, legible solo por el usuario de despliegue.                                                                                                             |
| Retención       | Catorce días, que cubren el sprint en curso.                                                                                                                                                                         |

*Continúa en la página siguiente*

| Elemento   | Política                                                                                                      |
|------------|---------------------------------------------------------------------------------------------------------------|
| Desarrollo | Sin respaldo. Los datos son sintéticos y los trabajos de migración los reconstruyen en el siguiente arranque. |

## 11.2 Restauración

Cada base se restaura sin tocar las demás. El procedimiento lo ejecuta, al menos una vez, alguien distinto de quien lo escribió, siguiendo solo este documento (T-311).

1. Se detiene el servicio propietario de la base afectada. Los demás siguen operando y degradan conforme a EC-08.
2. Se elimina el contenedor y el volumen de la base y se arranca de nuevo: el guion de inicialización crea los roles y el esquema vacío.
3. El trabajo `restauracion_<base>` verifica la suma SHA-256 del respaldo contra su manifiesto y ejecuta `pg_restore` con el rol de propietario.
4. Se ejecuta el trabajo de migración de la base, que aplica las migraciones posteriores al respaldo, si las hay.
5. Se comprueba que la versión de esquema es la esperada y que el número de filas de cada tabla coincide con el manifiesto.
6. Se arranca el servicio y se espera su sondeo de salud.
7. Se registran como evidencia la hora de inicio y de fin, que miden el tiempo de recuperación, y la marca temporal del respaldo, que mide la pérdida de datos.

**Objetivos.** Tiempo de recuperación de cuatro horas o menos y pérdida máxima de veinticuatro horas por base, conforme a EC-09. Los ensayos de los Sprints 2 a 4 validan el procedimiento sobre las bases que existen en cada uno, y el del Sprint 5 verifica los objetivos sobre el sistema completo.

## 11.3 Despliegue en QA

1. Una fusión en `main` publica la imagen de cada componente con su versión semántica y su identificador corto de commit.
2. DevOps fija en el archivo de variables de QA la versión de cada componente y ejecuta el respaldo bajo demanda.
3. Se descargan las imágenes del registro y se recrean los contenedores con Compose. Los trabajos de migración se ejecutan antes que sus servicios.
4. El despliegue se da por completo cuando los catorce contenedores están sanos y la prueba de humo —inicio de sesión, consulta de inventario y consulta pública de campañas— responde.

No se despliega durante una ventana de demostración ni en las veinticuatro horas previas a una Review. En el servidor no se compila nada: corre exactamente la imagen que produjo la cadena.

## 11.4 Reversión

Ante un despliegue fallido se restablecen en el archivo de variables las versiones anteriores y se recrean los contenedores. La reversión no requiere deshacer migraciones, porque toda migración se escribe en dos tiempos: una versión solo añade estructura compatible con la versión anterior del servicio, y la eliminación de lo que ya no se usa llega en la versión siguiente. Así, la versión anterior de cada servicio siempre funciona sobre el esquema más reciente.

## 12. Ambientes y configuración

### 12.1 Comparación de ambientes

La misma imagen corre en todos los ambientes; lo que cambia se inyecta.

**Tabla 32:** Configuración por ambiente.

| Aspecto                 | Desarrollo                                                                        | QA                                                           | Producción (declarada)                                 |
|-------------------------|-----------------------------------------------------------------------------------|--------------------------------------------------------------|--------------------------------------------------------|
| Anfitrión               | Equipo de cada integrante                                                         | Máquina virtual institucional                                | Varios anfitriones tras un balanceador                 |
| Contenedores            | 12 y 4 trabajos de migración                                                      | 14, 4 trabajos de migración y los de respaldo y restauración | Los de QA, con réplicas del gateway y de los servicios |
| Certificado             | Autoridad interna de Caddy                                                        | Autoridad interna de Caddy, raíz entregada al evaluador      | Autoridad pública por ACME                             |
| Secretos                | Archivos generados por el guion de inicialización, fuera del control de versiones | Secretos de Compose del usuario de despliegue                | Gestor externo con rotación automática                 |
| Datos                   | Sintéticos, recreados en cada arranque limpio                                     | Sintéticos, persistentes y respaldados                       | Reales, bajo la Ley 1581 de 2012                       |
| Nivel de registro       | Depuración                                                                        | Información                                                  | Información                                            |
| Límites de recursos     | Tabla 18                                                                          | Tabla 18                                                     | Dimensionados con la medición de QA                    |
| Observabilidad          | Instrumentación sin recolector                                                    | Prometheus y Grafana                                         | Prometheus, Grafana y agregación de registros          |
| Canal de notificaciones | Simulado                                                                          | Simulado                                                     | Proveedor de correo                                    |
| Puertos publicados      | 443 y 80 del borde, en el propio equipo                                           | 443 y 80 del borde                                           | 443 y 80 del balanceador                               |
| Despliegue              | Construcción local o descarga del registro                                        | Descarga del registro desde <code>main</code>                | Descarga del registro desde <code>main</code>          |
| Respaldo                | Ninguno                                                                           | Diario, catorce días                                         | Diario, cifrado y fuera del anfitrión                  |

### 12.2 Variables de configuración

**Tabla 33:** Variables de configuración principales.

| Variable                                  | Componentes                       | Valor o regla                                                                                    |
|-------------------------------------------|-----------------------------------|--------------------------------------------------------------------------------------------------|
| TZ                                        | Todos                             | UTC.                                                                                             |
| REDVITAL_AMBIENTE                         | Todos                             | desarrollo, qa o produccion.                                                                     |
| BORDE_DOMINIO, BORDE_TLS                  | Borde                             | Dominio del ambiente; <b>internal</b> en Desarrollo y QA, correo de registro ACME en Producción. |
| JWT_EMITOR, JWT_AUDIENCIA                 | Gateway y servicios               | redvital-identidad y redvital-api.                                                               |
| JWKS_URL                                  | Gateway y servicios               | http://identidad:8080/.well-known/jwks.json.                                                     |
| TASA_ANONIMA, TASA_AUTENTICADA            | Gateway                           | 60 y 300 peticiones por minuto.                                                                  |
| ORIGEN_MEDICION                           | Gateway                           | Vacía, salvo en la pila de medición: dirección del equipo que genera la carga.                   |
| PLAZO_SERVICIO                            | Gateway                           | 5 segundos.                                                                                      |
| PLAZO_ENTRE_SERVICIOS                     | Servicios                         | 3 segundos.                                                                                      |
| TOKEN_KID_FIRMA                           | Identidad                         | Identificador de la clave con la que se firma.                                                   |
| TOKEN_VIGENCIA, SESION_VIGENCIA           | Identidad                         | 15 minutos y 8 horas.                                                                            |
| BD_HOST, BD_NOMBRE, BD_CREDENCIAL_ARCHIVO | Servicios con base y sus trabajos | Nombre del contenedor de su base, nombre de la base y ruta del secreto en <b>/run/secrets</b> .  |
| CANAL_NOTIFICACIONES                      | Notificaciones                    | <b>simulado</b> o <b>correo</b> .                                                                |
| CICLO_ESCALAMIENTO, CICLO_VENCIMIENTO     | Donación                          | 15 minutos cada uno (ADR-013, EC-13).                                                            |
| VERSION_<COMPONENTE>                      | Archivo de orquestación           | Versión de la imagen que se despliega.                                                           |

### 12.3 Pila de medición

Las pruebas de carga y de sobrecarga se ejecutan sobre la misma composición de QA, levantada con otro nombre de proyecto en la máquina de QA, con la instancia que se muestra al cliente detenida y fuera de las ventanas de demostración. La carga la genera Gatling desde el equipo de un integrante, fuera de la máquina de QA, para que el generador no compita por los recursos que se miden; la variable **ORIGEN\_MEDICION** exime a ese origen de la escala anónima del límite de tasa (ADR-007). Las medidas se toman en el gateway y se leen en Prometheus. EC-16 y EC-26 se ejecutan como una sola campaña de medición.

### 12.4 Topología de referencia de Producción

Producción está declarada y no se construye: el sistema no opera con datos reales de personas. Se declara para que su ausencia sea una decisión y para que el paso a operación real tenga un punto de partida. Conserva las cinco zonas, las cinco fronteras y las dieciocho aristas, y cambia lo siguiente:

**Tabla 34:** Diferencias de la topología de referencia de Producción.

| Elemento             | En Producción                                                                                                                                           |
|----------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------|
| Borde                | Balanceador de carga con filtrado de peticiones de aplicación delante de varias réplicas del proxy de borde; certificado de autoridad pública por ACME. |
| Gateway y servicios  | Al menos dos réplicas de cada uno, en anfitriones distintos.                                                                                            |
| Tráfico interno      | TLS mutuo entre servicios, con certificados emitidos por una autoridad interna.                                                                         |
| Bases                | Primaria con réplica de lectura por base; respaldo cifrado fuera del anfitrión.                                                                         |
| Secretos             | Gestor externo con rotación automática.                                                                                                                 |
| Notificaciones       | Proveedor de correo real; el trabajador sale al exterior por una red de salida propia, restringida a ese proveedor.                                     |
| Observabilidad       | Agregación centralizada de registros.                                                                                                                   |
| Orquestación         | La exclusión de Kubernetes del catálogo se reabre en la Mesa de Arquitectura, no se hereda.                                                             |
| Obligaciones legales | Retención, derecho de supresión y notificación de incidentes de la Ley 1581 de 2012; revisión de la ventana de revocación de quince minutos del token.  |

## 13. Riesgos de infraestructura aceptados

**Tabla 35:** Riesgos de infraestructura aceptados.

| ID     | Riesgo                                                                                                | Por qué se acepta                                                                                                                                                              | Qué lo cambiaría                               |
|--------|-------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------|
| RIF-01 | Tráfico HTTP sin cifrar dentro de las redes internas.                                                 | Las redes no salen del anfitrión y los tokens van firmados. TLS mutuo exigiría operar una autoridad de certificados interna para diez componentes.                             | Producción, o más de un anfitrión en QA.       |
| RIF-02 | Las imágenes oficiales de Caddy, PostgreSQL, Prometheus y Grafana conservan su intérprete de órdenes. | Reconstruirlas haría al equipo mantenedor de productos ajenos. Se compensa con usuario no privilegiado, raíz de solo lectura, sin capacidades, fijación por resumen y escaneo. | Una vulnerabilidad explotable en una de ellas. |
| RIF-03 | Una sola máquina de QA y una sola instancia del gateway son punto común de fallo.                     | Ambiente académico sin presupuesto (CP-03); reinicio automático y reversión rápida.                                                                                            | Producción.                                    |

*Continúa en la página siguiente*

| ID     | Riesgo                                                                                                                                       | Por qué se acepta                                                                                                                 | Qué lo cambiaría                              |
|--------|----------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------|
| RIF-04 | Una denegación de servicio distribuida desde muchos orígenes no se contiene en el anfitrión.                                                 | El límite por origen contiene el abuso simple, que es lo que exige EC-06. La contención volumétrica requiere un servicio externo. | Producción, con el balanceador y su filtrado. |
| RIF-05 | El registro de acceso del borde no está firmado y no prueba el no repudio.                                                                   | El no repudio lo sostiene la bitácora de auditoría (EC-05), no el registro de acceso.                                             | Ninguno previsto.                             |
| RIF-06 | Los respaldos de QA no se cifran.                                                                                                            | Contienen solo datos sintéticos (CP-04) y son legibles solo por el usuario de despliegue.                                         | Cualquier dato real.                          |
| RIF-07 | Las métricas viajan sin autenticación dentro de la red.                                                                                      | No son evidencia de seguridad sino de desempeño, y la red es interna.                                                             | Producción.                                   |
| RIF-08 | Un componente comprometido de <b>red_aplicacion</b> alcanza las rutas públicas de los servicios sin pasar por el límite de tasa del gateway. | Exige comprometer antes un componente interno, y esas rutas no entregan nada que no entreguen a través del gateway.               | Producción, con TLS mutuo.                    |

## 14. Verificación

Cada control de este documento se comprueba con uno de los procedimientos siguientes. Un control se da por cumplido solo cuando existe la evidencia indicada, producida sobre la composición real y registrada en el Informe de Evaluación del sprint en que se ejecuta.

**Tabla 36:** Procedimientos de verificación y evidencia que los cierra.

| ID   | Qué verifica                            | Procedimiento                                                                                                                                                                                                                    | Evidencia                                                                                     | Origen |
|------|-----------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------|--------|
| V-01 | Invariantes estructurales IT-01 a IT-04 | Sobre la composición resuelta por Compose, un guion de <b>redvital-infra</b> compara puertos publicados, pertenencia a redes y redes internas con las Tablas 10 y 11. Se ejecuta en cada Pull Request de <b>redvital-infra</b> . | Etapa en verde; un Pull Request de ensayo que añade una red a un servicio queda bloqueado.    | T-302  |
| V-02 | Aislamiento de red de las bases         | Desde un contenedor temporal de PostgreSQL unido a <b>red_borde</b> y luego a <b>red_aplicacion</b> , <b>pg_isready</b> contra las cuatro bases; desde cada red de datos, contra su base y contra las otras tres.                | Ocho intentos fallidos desde borde y aplicación; en cada red de datos, solo su base responde. | T-302  |
| V-03 | Credencial cruzada                      | Dentro de la red de <b>db_donacion</b> , conexión con el rol de servicio de otro contexto.                                                                                                                                       | Autenticación rechazada.                                                                      | T-405  |

*Continúa en la página siguiente*

| ID   | Qué verifica                        | Procedimiento                                                                                                                                                            | Evidencia                                                                                                                                             | Origen       |
|------|-------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------|--------------|
| V-04 | Rutas internas no enrutadas         | Desde fuera, peticiones a <code>/api/internal/...</code> y a <code>/api/.well-known/jwks.json</code> .                                                                   | Respuesta 404 en todas.                                                                                                                               | T-410        |
| V-05 | Sujetos de las operaciones internas | Prueba automatizada que invoca cada operación de la Tabla 13 con un sujeto no admitido.                                                                                  | Rechazo en todos los casos; aceptación con el sujeto admitido.                                                                                        | T-409        |
| V-06 | Plazos de espera                    | Con cada servicio par detenido, se invoca la operación que lo necesita.                                                                                                  | Respuesta degradada en 3 segundos o menos; 503 del gateway a los 5 segundos.                                                                          | EC-08        |
| V-07 | Roles de base de datos              | Con el rol de servicio: actualización y borrado sobre las tablas de solo anexo y creación de una tabla. Con el rol de propietario: creación de una tabla.                | Permiso denegado en los tres primeros casos; el último se admite.                                                                                     | T-405        |
| V-08 | Borde                               | Conexión con TLS 1.1; petición HTTP; cuerpo de 2 MiB; lectura de cabeceras de respuesta; cabecera <code>X-Forwarded-For</code> forjada; revisión del registro de acceso. | TLS 1.1 rechazado; redirección 301; 413; cabeceras presentes y <code>Server</code> ausente; origen forjado ignorado; sin credenciales en el registro. | T-305        |
| V-09 | Endurecimiento                      | Inspección de cada contenedor en ejecución.                                                                                                                              | Usuario distinto de 0, raíz de solo lectura, capacidades retiradas, sin escalada y límites declarados en los catorce.                                 | T-306        |
| V-10 | Imágenes sin intérprete             | Arranque de cada imagen propia con <code>sh</code> como punto de entrada, y listado de su sistema de archivos.                                                           | Fallo por ejecutable inexistente; ningún intérprete en el listado.                                                                                    | T-307        |
| V-11 | Detección de secretos               | Pull Request de ensayo con un secreto ficticio.                                                                                                                          | Fusión bloqueada.                                                                                                                                     | T-309        |
| V-12 | Rotación de la clave de firma       | Rotación ordinaria en QA con una sesión activa.                                                                                                                          | La sesión sigue renovándose tras retirar la clave anterior.                                                                                           | T-308        |
| V-13 | Escaneo de imágenes                 | Pull Request de ensayo con una imagen base de vulnerabilidad alta conocida.                                                                                              | Construcción fallida.                                                                                                                                 | T-310        |
| V-14 | Métricas sin datos protegidos       | Lectura de <code>/metrics</code> de cada servicio tras ejecutar el conjunto sintético.                                                                                   | Ninguna etiqueta fuera del conjunto acotado.                                                                                                          | EC-20        |
| V-15 | Acceso a observabilidad             | Acceso a Grafana sin sesión y con el usuario del evaluador; petición a <code>/prometheus</code> por el borde.                                                            | Inicio de sesión exigido; edición negada al evaluador; Prometheus inalcanzable.                                                                       | T-305        |
| V-16 | Denegaciones del gateway            | Petición sin token; luego la misma con Identidad detenida más de sesenta segundos.                                                                                       | Registro en la serie de Identidad; después, contador de no entregadas incrementado.                                                                   | EC-03        |
| V-17 | Puesta en marcha                    | Un comando en una máquina limpia de cada sistema operativo, cronometrado hasta que los doce contenedores de Desarrollo están sanos.                                      | Tiempo de diez minutos o menos en Windows, macOS y Linux.                                                                                             | T-408, EC-23 |

*Continúa en la página siguiente*

| ID   | Qué verifica        | Procedimiento                                                                     | Evidencia                                                                   | Origen       |
|------|---------------------|-----------------------------------------------------------------------------------|-----------------------------------------------------------------------------|--------------|
| V-18 | Consumo en reposo   | Lectura del consumo de memoria tras diez minutos de reposo en Desarrollo y en QA. | Menos de 4 GB en Desarrollo; consumo de cada contenedor frente a su límite. | T-411, EC-27 |
| V-19 | Restauración        | Procedimiento de la Sección 11 por alguien distinto de su autor.                  | Tiempos de inicio y fin, manifiesto conciliado.                             | T-311, EC-09 |
| V-20 | Reinicio automático | Terminación forzada de cada servicio.                                             | Sano de nuevo en 60 segundos o menos, sin intervención.                     | EC-07        |
| V-21 | Reversión           | Despliegue de la versión anterior tras uno de ensayo.                             | Catorce contenedores sanos y prueba de humo superada.                       | T-312        |

## 14.1 Correspondencia con el backlog

**Tabla 37:** Tareas del Sprint 2 y su lugar en este documento.

| Tarea        | Qué produce                                                | Sección y verificación |
|--------------|------------------------------------------------------------|------------------------|
| T-301        | Matriz de alcanzabilidad                                   | Sección 3; V-01        |
| T-302        | Invariante borde-datos y su comprobación                   | Sección 3; V-01, V-02  |
| T-303, T-304 | Modelo de amenazas con control o riesgo aceptado por celda | Secciones 8 y 13       |
| T-305        | Configuración por ambiente                                 | Sección 12; V-08, V-15 |
| T-306, T-307 | Endurecimiento e imágenes sin intérprete                   | Sección 5; V-09, V-10  |
| T-308        | Origen de los secretos y rotación de la clave              | Sección 7; V-12        |
| T-309, T-310 | Detección de secretos y escaneo de imágenes                | Sección 9; V-11, V-13  |
| T-311        | Respaldo y restauración de las cuatro bases                | Sección 11; V-19       |
| T-402, T-403 | Sondas de salud y composición encadenada                   | Sección 4; V-17, V-20  |
| T-404, T-405 | Trabajos de migración y roles por base                     | Sección 6; V-03, V-07  |
| T-408, T-411 | Medición de arranque y de memoria                          | Sección 4; V-17, V-18  |

## 15. Gobierno del documento

**Tabla 38:** Responsabilidad sobre los contenidos de este documento.

| Contenido                              | Quién lo cambia                 | Condición                                                                                   |
|----------------------------------------|---------------------------------|---------------------------------------------------------------------------------------------|
| Zonas, fronteras, redes y aristas      | Mesa de Arquitectura            | Solo con un ADR que modifique ADR-014, y en el mismo cambio que el archivo de orquestación. |
| Puertos, límites, sondas, variables    | DevOps                          | En el mismo Pull Request que el archivo de orquestación, con visto bueno de la Arquitecta.  |
| Presupuesto de recursos                | DevOps                          | Solo con medición registrada que lo justifique.                                             |
| Modelo de amenazas y riesgos aceptados | Arquitecta de Software y DevOps | Toda amenaza nueva recibe control o riesgo aceptado antes de cerrarse.                      |
| Procedimientos de verificación         | QA con DevOps                   | Toda verificación nueva declara su evidencia.                                               |

Este documento se revisa al cierre de cada sprint junto con el SAD. Una cifra que la medición contradiga se corrige con registro del ajuste; lo que no puede ocurrir es que la composición real y este documento digan cosas distintas.

## A. Declaración de un servicio en el archivo de orquestación

Extracto del archivo de `redvital-infra` para el Servicio de Donación. Los demás servicios siguen el mismo patrón con su imagen, su base, sus secretos y su sonda.

```
services:
  donacion:
    image: ghcr.io/redvital/donacion-service:${VERSION_DONACION}
    user: "65532:65532"
    read_only: true
    tmpfs: [/tmp]
    cap_drop: [ALL]
    security_opt: ["no-new-privileges:true"]
    mem_limit: 768m
    cpus: 1.5
    restart: unless-stopped
    environment:
      TZ: UTC
      REDVITAL_AMBIENTE: ${REDVITAL_AMBIENTE}
      JWKS_URL: http://identidad:8080/.well-known/jwks.json
      JWT_EMITOR: redvital-identidad
      JWT_AUDIENCIA: redvital-api
      BD_HOST: db_donacion
      BD_NOMBRE: donacion
      BD_CREDENCIAL_ARCHIVO: /run/secrets/db_donacion_servicio
      PLAZO_ENTRE_SERVICIOS: 3s
      CICLO_ESCALAMIENTO: 15m
      CICLO_VENCIMIENTO: 15m
      JAVA_TOOL_OPTIONS: -XX:MaxRAMPercentage=70
    secrets: [db_donacion_servicio, credencial_donacion]
    networks: [red_aplicacion, red_datos_donacion]
    depends_on:
      migracion_donacion:
        condition: service_completed_successfully
```

```

    identidad:
      condition: service_healthy
  healthcheck:
    test: ["CMD", "/opt/java/bin/java", "-Xmx16m", "-XX:TieredStopAtLevel=1",
          "-cp", "/app/sonda.jar", "Sonda", "http://localhost:8081/salud"]
    interval: 15s
    timeout: 3s
    retries: 3
    start_period: 60s
  logging:
    driver: json-file
    options: {max-size: "10m", max-file: "3"}

networks:
  red_borde: {}
  red_aplicacion: {internal: true}
  red_datos_donacion: {internal: true}

```

## B. Configuración del proxy de borde

Archivo de configuración de Caddy en `redvital-infra`. Las variables `BORDE_DOMINIO`, `BORDE_TLS` y `REDVITAL_AMBIENTE` son las únicas diferencias entre ambientes. Caddy redacta por defecto las cabeceras de credenciales y las cookies en su registro de acceso, y no acepta cabeceras de reenvío de un cliente que no declara como intermediario de confianza.

```

{
  admin off
  http_port 8080
  https_port 8443
}

(grafana_desarrollo) {
}

(grafana_qa) {
  handle /grafana/* {
    reverse_proxy grafana:3000
  }
}

(grafana_produccion) {
}

{${BORDE_DOMINIO}} {
  tls {${BORDE_TLS}} {
    protocols tls1.2 tls1.3
  }

  header {
    Strict-Transport-Security "max-age=31536000"
    Content-Security-Policy "default-src 'self'; frame-ancestors 'none'"
    X-Content-Type-Options "nosniff"
    Referrer-Policy "no-referrer"
    Permissions-Policy "camera=(), microphone=(), geolocation=()"
    -Server
  }

  log {
    output stdout
    format json
  }
}

```

```
}

handle /api/* {
    request_body {
        max_size 1MiB
    }
    reverse_proxy gateway:8080
}

import grafana_{$REDVITAL_AMBIENTE}

handle {
    reverse_proxy web:8080
}
}
```

Este documento describe la infraestructura de un sistema académico que opera exclusivamente sobre datos sintéticos. La topología de Producción es de referencia y no está construida.